

PROJECT_DOCUMENTATION

Real Estate Due Diligence Platform — Project Documentation

Exhaustive technical documentation of the full-stack platform. Generated from the actual source code (August 2026).

Repo: [springboardmentor198/team-03](#) · Branch: [develop](#) · License: MIT

Live: Frontend <https://team-03.vercel.app> · Backend <https://dd-backend.onrender.com> (health: </actuator/health>, Swagger: </swagger-ui.html>)

Table of Contents

- [1. Project Overview](#)
- [2. Architecture](#)
- [3. Role-Based Access Control \(RBAC\)](#)
- [4. Feature List](#)
- [5. Database Schema](#)
- [6. API Endpoints](#)
- [7. Frontend Pages & Routes](#)
- [8. Security Measures](#)
- [9. Testing](#)
- [10. DevOps & Deployment](#)
- [11. Project Structure](#)
- [12. Design System](#)
- [13. Third-Party Integrations](#)
- [14. Known Issues & Fixes Applied](#)
- [15. Future Scope](#)
- [16. Recent Changes / Changelog](#)

1. Project Overview

1.1 What problem it solves

Buying property in India is high-risk and manually intensive. Buyers must independently verify legal ownership, tax history, zoning compliance, flood risk, environmental quality and market comparables — a process that normally takes weeks of scattered manual research across government offices and websites, and is the #1 vector for real-estate fraud (fake owners, disputed land, unauthorised construction).

The **Real Estate Due Diligence Platform** automates this: a buyer or agent enters a property address and gets a consolidated, AI-augmented due diligence report with a 0–100 risk score across 6 categories (Flood, Legal, Tax, Zoning, Environment, Market), a BUY / NEGOTIATE / AVOID verdict, fraud alert badges, and PDF/Excel exports — in minutes instead of weeks.

1.2 Target users (roles)

Role	Who	What they get
BUYER	Home/property buyers	Portfolio dashboard, property search, risk assessment, AI chat, due diligence reports, payment plans

Role	Who	What they get
REAL_ESTATE_AGENT	Brokers/agents	Everything a buyer has, plus report generation & export tools (/api/agent/** routes)
LEGAL_REVIEWER	Legal professionals	Report history, exports, audit access for legal review (/api/legal/**)
FINANCIAL_INSTITUTION	Banks, lenders	Risk data + exports for loan underwriting (/api/financial/**)
ADMIN	Platform operators	Full admin panel: user management (ban/unban, role change), analytics, audit logs, system health, subscription oversight

1.3 Value proposition

- **AI-powered:** Groq llama-3.3-70b-versatile (~500 tokens/sec) powers a property-assistant chat with cited sources and generates the executive summary of every report with a verdict.
- **Automated risk scoring:** multi-factor weighted scoring engine persists assessments with version history and delta tracking.
- **Fraud detection:** severity-tiered fraud alert badges (CRITICAL pulsing red / HIGH amber / verified LOW) derived from risk levels.
- **One-click exports:** professional PDF (iText) and Excel (Apache POI, 3 sheets) exports of every report, plus property-level exports.
- **Zero-friction payments:** Cashfree UPI checkout with ₹499 Pro / ₹1,999 Business plans, webhook-verified activation.
- **11 languages:** i18n across English, Hindi, Bengali, Tamil, Telugu, Marathi, Gujarati, Kannada, Malayalam, Punjabi, Urdu (RTL).
- **Free-tier deployable:** entire stack runs on Vercel + Render + Postgres free tiers (~₹0/month).

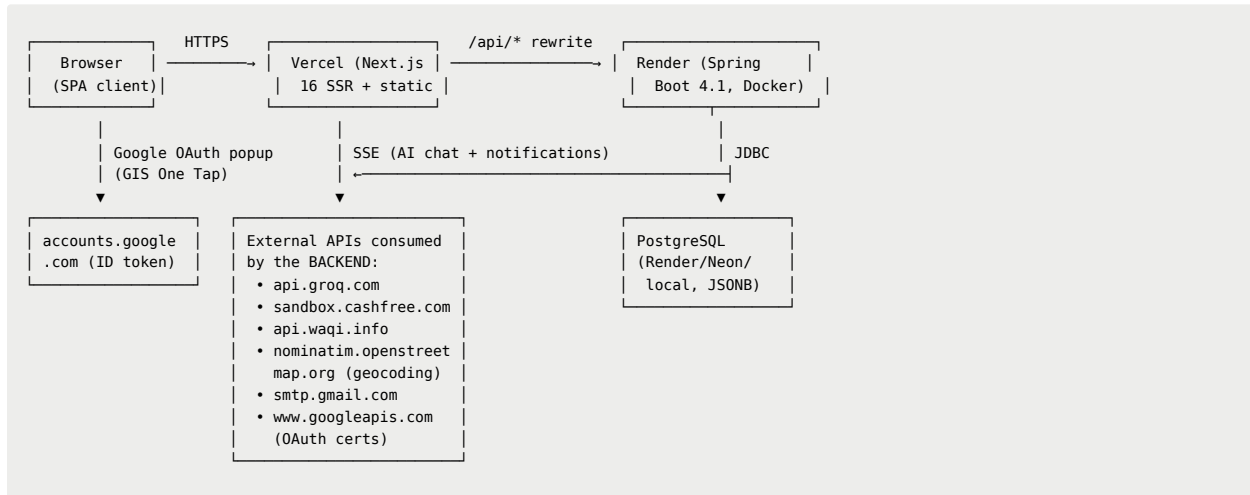
1.4 Tech stack (exact versions)

Layer	Technology	Version
Backend framework	Spring Boot (parent spring-boot-starter-parent)	4.1.0
Backend language	Java	17 (Temurin)
Frontend framework	Next.js (App Router, Turbopack dev)	16.2.10
Frontend library	React / React-DOM	19.2.4
CSS framework	Tailwind CSS (+ @tailwindcss/postcss)	v4
Database	PostgreSQL	16 (Docker postgres:16-alpine ; local dev 18)
ORM	Hibernate (JPA) via Spring Data JPA	included in Boot 4.1.0
JWT library	jjwt (io.jsonwebtoken)	included in Boot 4.1.0
Build tools	Maven (wrapper 3.3.4 → Maven 3.9.16), npm	—
Runtime (Docker)	Node.js 20-alpine, Eclipse Temurin JRE 17-alpine	—
API docs	springdoc-openapi-starter-webmvc-ui	2.8.0
Coverage	JaCoCo Maven plugin	0.8.12
Frontend testing	Vitest + Testing Library + jsdom	2.1.8 / 16.1.0 / 25.0.1
Key frontend libs	framer-motion 12.42.2, axios 1.18.1, i18next 24.2.3, react-i18next 15.5.1, sonner 2.0.7, recharts 3.10.0, leaflet 1.9.4, react-leaflet 5.0.0, react-markdown 10.1.0, @react-pdf/renderer 4.5.1, @react-oauth/google 0.13.5, canvas-confetti 1.9.4, @base-ui/react 1.6.0, nextjs-toploader 3.9.17, lucide-react 1.24.0	

Layer	Technology	Version
Backend key libs	bucket4j (rate limiting), google-api-client (OAuth ID-token verify), Cashfree SDK/API via WebClient, iText (PDF), Apache POI (Excel)	

2. Architecture

2.1 System architecture



Key decisions (from `docs/ARCHITECTURE.md`):

- Next.js App Router for SSR/TTFB; Spring Boot 4.1 for the API; PostgreSQL for ACID + JSONB.
- The browser **only ever calls same-origin** `/api/*` — no client-side CORS in production. Next.js rewrites proxy to the backend.
- AI chat streams over SSE with `X-Accel-Buffering: no` / `Transfer-Encoding: chunked` exposed headers so proxies don't buffer tokens.
- Zero-cost deployment: Vercel (frontend) + Render (backend, Docker) + Render Postgres or Neon.

2.2 Request lifecycle (data flow)

1. Browser calls `GET /api/properties` (same-origin).
2. `frontend/next.config.mjs` rewrite: `/api/:path*` → `${API_PROXY_URL} || "http://localhost:8080"/api/:path*` (production: `frontend/vercel.json` rewrite to `https://dd-backend.onrender.com`; Docker: `API_PROXY_URL=http://backend:8080` build arg).
3. Spring Security filter chain on the backend: `RateLimitFilter` (Bucket4j per-IP buckets) → `JwtAuthenticationFilter` (Bearer/cookie token validation) → `AuthorizationFilter` (role matchers).
4. Controller → Service → Repository (Spring Data JPA, parameterized queries) → PostgreSQL.
5. Response is JSON (uniform `ApiResponse` / DTO shapes); errors pass through `GlobalExceptionHandler` (`@RestControllerAdvice`).

2.3 Authentication flows

Email/password (3-step OTP registration):

```

POST /api/auth/register/send-otp → validates, creates PendingRegistration (BCrypt-hashed password + OTP), emails 6-digit OTP (@Async)
POST /api/auth/register/verify-otp → verifies OTP (BCrypt.matches), creates User, issues JWT, deletes pending row, sends welcome + login-alert emails
POST /api/auth/login → AuthenticationManager (DaoAuthenticationProvider → CustomUserDetailsService) → JWT (HS256, 1h expiry)
  
```

Google OAuth (2-step):

1. Browser: Google Identity Services (GIS) popup → ID token (clientId = NEXT_PUBLIC_GOOGLE_CLIENT_ID)
2. POST /api/auth/google { credential } → GoogleTokenVerifier verifies the ID token against Google's certs (audience = GOOGLE_CLIENT_ID)
 - existing user → { status: "AUTHENTICATED", token } (JWT issued)
 - unknown email → { status: "PROFILE_INCOMPLETE", email, name, picture }
3. New users complete profile → POST /api/auth/complete-google-signup { credential, role, phoneNumber }
 - creates User (authProvider=GOOGLE, password NULL, googleId set) → JWT

Session model: stateless JWT (HS256, 1 h expiry). Token stored in localStorage (remember-me) or sessionStorage, **plus an auth_token cookie** (SameSite=Strict) so the Next.js middleware layer and cookie-authenticated server downloads can read it. "Logout of all devices" stamps `users.token_valid_from`; the JWT filter rejects any token whose `iat` predates it.

2.4 SSE streaming (AI chat)

```
POST /api/agent/chat/stream { message, propertyId?, history? }
→ AgentChatServiceImpl (reactive WebClient, fresh connection per request)
→ https://api.groq.com/openai/v1/chat/completions (llama-3.3-70b-versatile, stream:true,
  max_tokens 1024, temperature 0.7, responseTimeout 120s, Retry.backoff(1, 400ms))
→ per-token chunks Base64-encoded → SseEmitter(300_000 ms) → "data: <base64>" lines
→ frontend useAgentChat.js decodes Base64 and appends (AbortController for stop)
```

A second SSE channel (`GET /api/sse/notifications?token=...`) delivers notifications: singleton frontend `EventSource` with exponential backoff (1 s → 30 s + ±400 ms jitter), paused when the tab is hidden; backend `NotificationEventPublisher` keeps per-user emitter lists in a `ConcurrentHashMap` and sends `ping` events on connect.

2.5 Payment flow (Cashfree)

1. GET /api/subscription/current → current plan/usage
2. POST /api/subscription/create-order { plan } → Cashfree Payment Links API
 - POST https://sandbox.cashfree.com/pg/links (x-api-version: 2023-08-01)
 - { link_url } (hosted checkout) → browser redirects to Cashfree
3. User pays (UPI/cards/netbanking)
4. Cashfree calls back (async): POST /api/subscription/webhook
 - HmacSHA256(raw body, CASHFREE_WEBHOOK_SECRET) vs x-webhook-signature header
 - PAYMENT_SUCCESS_WEBHOOK + order_status PAID → Subscription ACTIVE + welcome email
5. Browser return URL /checkout/success?order_id=... polls GET /api/subscription/verify-order every 2 s (max 8 attempts) → activates on PAID → confetti

Plans: **FREE** ₹0 (3 reports/mo) · **PRO** ₹499/mo (unlimited) · **BUSINESS** ₹1,999/mo (unlimited) · **ENTERPRISE** custom.

Cancel behavior (Netflix/Stripe pattern):

- Cancel sets `status=CANCELLED`, `cancelled_at=NOW()`, but `expires_at` is **UNCHANGED**.
- User keeps full paid access until `expires_at`.
- After expiry, auto-downgrades to FREE (checked on every `/current` call and in `enforcePlanLimit`).
- Backend check: `("ACTIVE".equals(status) || "CANCELLED".equals(status)) && expiresAt.isAfter(NOW())`.

Re-purchase behavior:

- Buying again while still ACTIVE extends by +1 month from current expiry (no lost days).
- Old subscription row marked **SUPERSEDED**, new row becomes authoritative.

Plan enforcement (`DueDiligenceReportServiceImpl.enforcePlanLimit`):

- ADMIN + LEGAL_REVIEWER + FINANCIAL_INSTITUTION: bypass entirely (unlimited).
- FREE plan or no subscription: 3 reports/month, throws `PlanLimitExceededException` → HTTP 402 {error: "PLAN_LIMIT_EXCEEDED", upgradeUrl: "/checkout?plan=pro"}.
- PRO/BUSINESS/ENTERPRISE with valid (ACTIVE or CANCELLED-not-expired) subscription: unlimited.

2.6 Report pipeline

```
POST /api/reports/generate { propertyId, title, forceRiskRecalculation }
→ DueDiligenceReportServiceImpl → ReportGenerationExecutor (@Async reportTaskExecutor with
  security-context propagation) → status PENDING → background pipeline:
```

```

    aggregation (ownership/tax/zoning/flood/permits/environmental, live where available,
    cached/mock fallback) → ReportSectionBuilder (8 sections)
    → risk assessment (RiskScoringEngine, 6 weighted categories, snapshot on report)
    → AI executive summary (ReportSummaryServiceImpl → Groq, json_object, 60 s regenerate cooldown)
    → frontend polls GET /api/reports/{id}/status every 2 s (max 150 attempts) → COMPLETED
    → PDF/Excel export via ExportController (iText 7 / Apache POI, 3 sheets)

```

3. Role-Based Access Control (RBAC)

Five roles with strict boundaries enforced on both backend (`@PreAuthorize` + service-layer role checks) and frontend (route guards + UI visibility).

Feature	ADMIN	BUYER	AGENT	LEGAL_REVIEWER	FINANCIAL_INSTITUTION
View all properties	✓ ALL	Own only	Own only	✓ ALL	✓ ALL
Add property	✓	✓	✓	✗ Hidden	✗ Hidden
Edit property	✓ Any	Own only	Own only	✗ Hidden	✗ Hidden
Delete property	✓ Any	Own only	Own only	✗ Hidden	✗ Hidden
Generate report	✓ Unlimited	Plan limit	Plan limit	✓ Unlimited	✓ Unlimited
Delete report	✓	✓ Own	✓ Own	✗ 403	✗ 403
AI chat	✓	✓	✓	✓	✓
Export PDF/Excel	✓	✓	✓	✓	✓
Compare properties	✓	✓	✓	✓	✓
View comparables/valuation	✓	✓ Own	✓ Own	✓ Any	✓ Any
Risk assessment	✓	✓ Own	✓ Own	✓ Any	✓ Any
AI summary	✓	✓ Own	✓ Own	✓ Any	✓ Any
Billing/Subscription page	✓	✓	✓	✗ Redirect	✗ Redirect
Checkout page	✓	✓	✓	✗ Redirect	✗ Redirect
Upgrade button (UI)	✓	✓	✓	✗ Hidden	✗ Hidden
Plan limit enforced	✗ No limit	✓ FREE=3/mo	✓ FREE=3/mo	✗ No limit	✗ No limit
Admin panel	✓	✗	✗	✗	✗
Analytics dashboard	✓	✗	✗	✗	✗
Audit trail	✓	✗	✗	✗	✗

RBAC Implementation

- **Shared helper:** `com.realestate.duediligence.util.RoleUtils` — `isAdmin()`, `isPaidProfessionalRole()` (LEGAL_REVIEWER / FINANCIAL_INSTITUTION), `canViewAllProperties()`, `canAccessProperty()` (owner-or-view-all).
- **Backend read authorization** uses `canViewAllProperties()` in: `PropertyServiceImpl`, `DashboardServiceImpl`, `PropertyAggregationService`, `ComparablePropertyServiceImpl`, `PropertyValuationServiceImpl`, `RiskAssessmentServiceImpl`, `ReportSummaryServiceImpl`.
- **Backend write authorization:** `isAdmin()` for admin bypass; owner-only for BUYER/AGENT; LEGAL/FIN excluded from property CRUD and report deletion (`403 AccessDeniedException`).
- **Controller guards:** class-level `@PreAuthorize("hasRole('ADMIN')")` on `AuditLogController`, `HealthCheckController`, `TestController`, `AdminController`; `PropertyController` / `PropertyLabelController` writes role-gated; `ComparablePropertyController` + `SavedComparisonController` → `isAuthenticated()` (all roles).
- **Subscription/plan:** `enforcePlanLimit()` in `DueDiligenceReportServiceImpl` bypasses ADMIN + pro roles; `GET /api/subscription/current` reports pro roles as unlimited `PRO`.
- **Frontend guards:** `AuthGuard.jsx` (billing/checkout redirects), `Sidebar.jsx` (menu visibility, admin platform menu), `Navbar.jsx` (upgrade button hidden), `CommandPalette.jsx` (add-property action filtered), property/report action buttons

(Edit/Delete/Delete-Report gated per role). Note: there is no `middleware.ts` — `AuthGuard` is the client-side RBAC layer.

4. Feature List

Every feature with its implementing files and internal behaviour.

4.1 Authentication & Authorization

Feature	Frontend files	Backend files
Email/password signup (3-step OTP)	<code>frontend/src/app/register/page.js</code> , <code>frontend/src/components/forms/RegisterForm.jsx</code> , <code>frontend/src/components/auth/OtpVerificationModal.jsx</code> , <code>frontend/src/services/authService.js</code>	<code>backend/src/main/java/com/realestate/duediligence/contr</code> (<code>POST /api/auth/register/send-otp</code> , <code>/verify-otp</code> , <code>/resenc</code> <code>service/impl/UserServiceImpl.java</code> , <code>entity/PendingRegistr</code> <code>repository/PendingRegistrationRepository.java</code> , <code>service/</code>
Email/password login	<code>frontend/src/app/login/page.js</code> (inline form, caps-lock detection, <code>?redirect=</code>), <code>frontend/src/services/authService.js</code> (<code>loginUser</code>)	<code>AuthController.login</code> → <code>UserServiceImpl.login</code>
Google OAuth sign-in (One Tap + fallback)	<code>frontend/src/components/auth/GoogleSignInButton.jsx</code> , <code>frontend/src/app/providers.jsx</code> (<code>GoogleOAuthProvider</code>), <code>frontend/src/app/complete-profile/page.jsx</code> , <code>frontend/src/services/authService.js</code>	<code>AuthController.loginWithGoogle</code> / <code>completeGoogleSignup</code> , <code>service/GoogleTokenVerifier.java</code> , <code>integration/GoogleOAuth</code>
JWT token management	<code>frontend/src/utils/helpers.js</code> (<code>saveToken/getToken/removeToken</code>), <code>frontend/src/services/api.js</code> (request interceptor adds <code>Authorization: Bearer</code>)	<code>util/JwtService.java</code> (<code>generateToken</code> , <code>extractUsername</code> , <code>extractIssuedAt</code>), <code>security/JwtAuthenticationFilter.java</code>
Role-based access (5 roles)	<code>frontend/src/components/AuthGuard.jsx</code> (client RBAC + <code>ROUTE_ROLES</code>), <code>frontend/src/components/AdminGuard.jsx</code> , <code>frontend/src/components/GuestGuard.jsx</code> , <code>frontend/src/components/layout/Sidebar.jsx</code> (role-based menus)	<code>security/SecurityConfig.java</code> request matchers (<code>/api/adm</code> <code>/api/legal/**</code> , <code>/api/financial/**</code> , <code>/api/agent/**</code>), <code>enum</code> <code>entity/Role.java</code>
Password reset via OTP email	<code>frontend/src/app/forgot-password/page.jsx</code> (4-step wizard, 45 s resend cooldown)	<code>AuthController.forgotPassword</code> / <code>verifyOtp</code> / <code>resetPasswo</code>
Session invalidation (logout all devices)	<code>frontend/src/components/profile/SignOutAllModal.jsx</code> , <code>frontend/src/services/authService.js</code> (<code>logoutAllDevices</code>)	<code>AuthController.logoutAllDevices</code> → <code>users.token_valid_fr</code> <code>JwtAuthenticationFilter</code> rejects tokens with <code>iat < token_</code>
Account ban/unban + <code>is_active</code>	<code>frontend/src/components/admin/UserManagementTable.jsx</code> , <code>UserDetailModal.jsx</code> (null-safe <code>isActive !== false</code>), <code>frontend/src/services/adminService.js</code> (<code>banUser/unbanUser</code>)	<code>UserManagementController</code> (<code>PUT /api/admin/users/{id}/bar</code> <code>CustomUserDetailsService</code> (<code>.disabled(!active banned)</code>)

4.2 Landing Page & Marketing

Feature	Files	Notes
Hero with animated gradients + scroll parallax	<code>frontend/src/components/landing/LandingPage.jsx</code> (framer-motion <code>useScroll</code> / <code>useTransform</code>), <code>frontend/src/app/page.js</code>	Auth-aware nav; marketing dark theme
Feature grid with motion primitives	<code>LandingPage.jsx</code> , <code>frontend/src/components/motion/CardHover.jsx</code> , <code>frontend/src/utils/animations.js</code>	<code>fadeInUp</code> , <code>staggerContainer</code> variants
Testimonials carousel	<code>LandingPage.jsx</code> , <code>frontend/src/app/contact/page.js</code>	—

Feature	Files	Notes
Pricing page	<code>frontend/src/app/pricing/page.js</code> (4 plans, FAQ, student discount banner)	CTAs: <code>/register</code> , <code>/checkout?plan=pro\ business</code> , <code>/contact?topic=enterprise</code>
Contact page	<code>frontend/src/app/contact/page.js</code> , backend <code>ContactController</code> + <code>EmailService.sendContactNotification</code>	Topics incl. enterprise/student via <code>?topic=</code>
Privacy policy / Terms	<code>frontend/src/app/privacy/page.js</code> , <code>frontend/src/app/terms/page.js</code>	Lists processors (Cashfree, Google, WAQI, Nominatim); IT Act 2000 references
Security page	<code>frontend/src/app/security/page.jsx</code>	Server component with own metadata
Documentation/API docs	<code>frontend/src/app/docs/page.js</code> , <code>frontend/src/app/docs/[slug]/page.js</code> , <code>frontend/src/lib/docsData.js</code>	Searchable article viewer by category
Support hub	<code>frontend/src/app/support/page.jsx</code> , <code>frontend/src/constants/faq.js</code>	FAQ search + mailto tiles (<code>duediligence8@gmail.com</code>)
SEO	<code>frontend/src/app/layout.js</code> (metadata: title, description, keywords, OG, twitter, <code>og-image.png</code> 1200×630), inline JSON-LD <code>SoftwareApplication</code> , skip-to-content link, <code>NextTopLoader</code>	metadataBase <code>https://realestate-duediligence.com</code>

4.3 Dashboard

Feature	Files	Notes
Role-based sidebar navigation	<code>frontend/src/components/layout/Sidebar.jsx</code> (separate admin platform menu vs transactional user menu), <code>frontend/src/components/layout/MainLayout.jsx</code>	Sidebar state persisted (<code>dd_sidebar_open</code>); auto-collapses < 1024 px
Dark/light theme toggle	<code>frontend/src/components/ThemeToggle.jsx</code> , <code>frontend/src/hooks/useTheme.js</code> (system media listener, no-flicker suppression), <code>frontend/src/app/providers.jsx</code> (ThemeProvider)	localStorage <code>theme</code> ; CSS vars in <code>globals.css</code> (GitHub-dark palette)
Internationalization	<code>frontend/src/i18n/index.js</code> , 11 <code>src/locales/*/translation.json</code> , <code>frontend/src/components/language/LanguageModal.jsx</code> + <code>LanguageTrigger.jsx</code> , <code>frontend/src/hooks/useLocale.js</code> , <code>frontend/src/i18n/formatters.js</code>	11 languages (en/hi/bn/ta/te/mr/gu/kn/ml/pa/ur; ur RTL; kn/ml/pa/ur beta); lazy-loaded namespaces; persisted <code>i18n_lang</code>
Command palette (Ctrl+K)	<code>frontend/src/components/CommandPalette.jsx</code> (active), <code>frontend/src/hooks/useCommandPalette.js</code>	Page navigation + live property search + recent searches (max 5, localStorage)
Notification system	<code>frontend/src/components/notifications/*</code> (<code>NotificationItem/Group/Empty</code>), <code>frontend/src/app/dashboard/notifications/page.js</code> , <code>frontend/src/hooks/useNotifications.js</code> , <code>useUnreadCount.js</code> , <code>useSse.js</code>	SSE real-time + 60 s poll fallback; bell + <code>UnreadBadge</code> (99+ cap) in Navbar
Connection status pill	<code>frontend/src/components/layout/ConnectionStatus.jsx</code>	<code>subscribeToConnectionState</code> SSE reconnecting pill with green “recovered” flash
Responsive design	throughout — Tailwind breakpoints <code>sm/md/lg/xl</code>	—

4.4 Property Management

Feature	Files	Notes
Add property	<code>frontend/src/components/property/AddPropertyModal.jsx</code> (address autocomplete, <code>ImageUploader</code> , <code>SearchableSelect</code> INDIAN_STATES/CITIES)	<code>POST /api/properties</code> ; geocoding via Nominatim
Property listing with search/filter	<code>frontend/src/app/dashboard/property-search/page.js</code> , <code>SearchBar.jsx</code> (Nominatim autocomplete), <code>FilterPanel.jsx</code> , <code>ActiveFilterChips.jsx</code> , <code>usePropertyFilters.js</code> , <code>useAddressAutocomplete.js</code>	Client-side filter engine + backend keyword search

Feature	Files	Notes
Property detail	<code>frontend/src/app/dashboard/property-search/[id]/page.js</code> , <code>PropertyDetails.jsx</code> , <code>PropertyHeroCard.jsx</code> , <code>RiskScoreCard.jsx</code> , aggregation cards	Risk batch fetch with concurrency 4
Edit/delete	<code>EditPropertyModal.jsx</code> (auto re-verify on update), <code>propertyService.js</code>	<code>PUT /api/properties/{id}</code> , <code>DELETE /api/properties/{id}</code>
Verification status	<code>Property.verified</code> flag + aggregation <code>DataSourceBadge</code> (LIVE/CACHED/MOCK/NO_DATA)	Backend <code>PUT /api/properties/admin/reverify-all</code> re-verifies all
Property labels (Zillow-style)	<code>components/property/PropertyLabel*.jsx</code> , <code>frontend/src/constants/labels.js</code> , <code>frontend/src/utils/labelUtils.js</code> , <code>propertyLabelService.js</code>	NEW/HOT/PRICE_DROP/FEATURED/VERIFIED/PREMIUM with expiry; admin recalculation endpoint
Property comparison	<code>frontend/src/app/dashboard/property-comparison/page.jsx</code> , <code>CompareBar.jsx</code> , <code>useCompareSelection.js</code> (max 3, <code>sessionStorage</code>)	<code>MarketValueChart</code> , side-by-side table, save/reopen comparisons, comparison PDF
Comparables & valuation	<code>frontend/src/app/properties/[id]/comparables/page.jsx</code> , <code>comparables/*</code> components (Leaflet <code>ComparableMap</code> , <code>PriceHeatmap</code> , <code>RadiusSelector</code>), <code>frontend/src/app/properties/[id]/valuation/page.jsx</code>	Haversine radius filtering; valuation methods chart, price trends

4.5 Due Diligence Reports

Feature	Files	Notes
Generate report	<code>frontend/src/app/properties/[id]/generate-report/page.jsx</code> , <code>frontend/src/hooks/useReport.js</code>	<code>POST /api/reports/generate</code> → 202 + reportId; polls <code>GET /api/reports/{id}</code> every 2 s (max 150)
8 report sections	<code>frontend/src/components/reports/sections/*</code> (<code>ReportCoverSection</code> , <code>ReportExecutiveSummary</code> , <code>ReportPropertyOverview</code> , <code>ReportRiskAnalysis</code> , <code>ReportComparableSection</code> , <code>ReportFinancialSection</code> , <code>ReportRecommendations</code> , <code>ReportAppendix</code>), <code>frontend/src/utils/reportUtils.js</code> (<code>SECTION_ORDER</code> , <code>sortSections</code>)	Each parses <code>section.dataJson</code>
AI summary with verdict	<code>frontend/src/components/reports/AISummaryCard.jsx</code> , backend <code>ReportSummaryServiceImpl</code> + <code>ReportSummaryController</code>	Groq <code>json_object</code> → PROCEED (<40) / CAUTION (40–70) / HIGH_RISK (>70); stored on report (<code>ai_summary</code> , <code>ai_summary_generated_at</code>); 60 s regenerate cooldown → 429
PDF export	<code>frontend/src/components/export/ExportButton.jsx</code> , backend <code>ExportController</code> + <code>PdfExportServiceImpl</code> (iText)	<code>GET /api/export/report/{id}/pdf</code> ; cookie-authenticated direct download
Excel export	same, <code>ExcelExportServiceImpl</code> (Apache POI)	3 sheets (risk table + factor rows)
Report history + versions	<code>frontend/src/app/dashboard/report-history/page.jsx</code> , <code>frontend/src/app/reports/page.jsx</code> (paginated 20/page, sort, filter), <code>ReportVersionHistoryModal.jsx</code>	<code>GET /api/report-history</code> , versions/archive/share endpoints
Report viewer + print	<code>frontend/src/app/reports/[reportId]/page.jsx</code> (TOC, sections, <code>HighRiskBanner</code> , confetti), <code>/reports/[reportId]/print/page.jsx</code> (auto <code>window.print()</code>)	—

4.6 Risk Assessment

Feature	Files	Notes
Multi-factor scoring	backend <code>service/impl/RiskAssessmentServiceImpl.java</code> , <code>entity/RiskAssessment.java</code>	6 categories (Flood, Legal, Tax, Zoning, Environment, Market) with weights; latest-wins with version history + delta

Feature	Files	Notes
Risk spectrum	<code>frontend/src/components/risk/RiskSpectrum.jsx</code> (animated ring gauge via <code>motion useMotionValue/useSpring/useTransform</code>), <code>frontend/src/app/dashboard/risk-assessment/page.jsx</code> , <code>frontend/src/app/properties/[id]/risk-analysis/page.jsx</code>	Levels (<code>RiskLevel.fromScore</code>): ≤25 LOW, ≤50 MEDIUM, ≤75 HIGH, else CRITICAL
Fraud alert badges	<code>frontend/src/components/property/FraudAlertBadge.jsx</code>	CRITICAL: pulsing red + rings; HIGH: amber; LOW: verified badge; MEDIUM renders nothing
Risk breakdown	<code>RiskBreakdownRadar.jsx</code> (6-axis radar), <code>RiskFactorCard.jsx</code> , <code>RiskExplainability.jsx</code> , <code>RiskHistorySection.jsx</code> + timeline/chart	CSV download of breakdown

4.7 AI Property Assistant

Feature	Files	Notes
Floating chat button	<code>frontend/src/components/agent/FloatingChatButton.jsx</code> (pulse ring FAB)	On property detail pages
Slide-out chat panel	<code>frontend/src/components/agent/ChatPanel.jsx</code> (markdown via <code>react-markdown</code> , suggested questions, stop/clear)	—
Real-time streaming	<code>frontend/src/hooks/useAgentChat.js</code> (fetch + ReadableStream, Base64 chunk decode, <code>[DONE]</code> terminator, AbortController) → backend <code>AgentChatController</code> + <code>AgentChatServiceImpl</code>	Groq <code>llama-3.3-70b-versatile</code> , stream:true, max_tokens 1024, temp 0.7, 120 s timeouts, Retry.backoff(1, 400ms)
Exponential backoff	<code>frontend/src/services/sseService.js</code> (1 s → 30 s + jitter, tab-hidden pause)	For notification SSE
Context-aware property questions	chat accepts <code>propertyId</code> + history (last 10 messages trimmed)	System prompt + property context

4.8 Payment & Billing

Feature	Files	Notes
Cashfree gateway (sandbox)	<code>frontend/src/app/checkout/page.js</code> , backend <code>CashfreeServiceImpl</code> (Payment Links API, <code>x-api-version: 2023-08-01</code> , sandbox/prod switch via <code>cashfree.environment</code>)	<code>POST /links</code> with <code>link_meta.return_url</code> + <code>notify_url</code>
Plan selection	<code>frontend/src/app/dashboard/billing/page.js</code> (FREE/PRO/BUSINESS/ENTERPRISE cards, usage), <code>frontend/src/app/pricing/page.js</code>	<code>enums/SubscriptionPlan.java</code> (amounts in paise)
Checkout flow	<code>frontend/src/app/checkout/page.js</code> (role guard: LEGAL/FIN → toast + redirect to <code>/dashboard</code> before any API call; real feature lists only)	Order persisted as PENDING <code>Subscription</code>
Success/failure handling	<code>frontend/src/app/checkout/success/page.js</code> (polls verify-order 2 s × 8; PAID/EXPIRED/FAILED/ACTIVE; role guard), <code>frontend/src/lib/celebrate.js</code> (confetti)	—
Webhook verification	backend <code>SubscriptionController.webhook</code>	HmacSHA256(raw body, webhook secret) vs <code>x-webhook-signature</code> ; dev-mode accept if secret unset
Cancel till expiry	backend <code>SubscriptionController.cancel</code> + <code>getCurrent</code>	<code>status=CANCELLED</code> , <code>expires_at</code> unchanged; paid access + unlimited reports kept until expiry, then FREE (Netflix/Stripe pattern); billing page shows “Cancelling on {date}” banner
Re-purchase	backend <code>SubscriptionController.activateSubscription</code>	Active re-purchase extends +1 month from current expiry; old row <code>SUPERSEDED</code>
Usage counter + upgrade UI	<code>frontend/src/app/properties/[id]/generate-report/page.jsx</code>	“🌟 Unlimited reports · {plan} plan” pill, “X of 3 free reports used” text, upgrade card replaces

Feature	Files	Notes
		generate button at 0 remaining; 402 → upgrade modal
Plan enforcement	backend <code>DueDiligenceReportServiceImpl.enforcePlanLimit</code>	ADMIN/pro-roles bypass; FREE = 3/month → <code>PlanLimitExceededException</code> → 402

Real features per plan (source of truth: `frontend/src/app/pricing/page.js`):

Plan	Features
FREE (₹0/forever)	3 due diligence reports/month · All 6 risk categories analyzed · PDF & Excel export · AI property assistant (chat) · AI-generated report summary · 1 saved property comparison · Fraud alert badges · Email support
PRO (₹499/month)	Everything in Free · Unlimited due diligence reports · Unlimited saved comparisons · Export history with re-download · Property comparison (up to 3) · Comparable properties + valuation · Risk assessment history & trends · Multi-language reports (11 languages)
BUSINESS (₹1,999/month)	Everything in Pro · Advanced analytics dashboard · Property portfolio insights · Notification preferences (email + in-app) · Audit trail on all actions · Bulk PDF/Excel export · Real-time updates (SSE) · Extended report history
ENTERPRISE (Custom)	Everything in Business · Custom deployment options · Volume-based pricing · Dedicated onboarding · Priority integration support · Custom risk category weights · Extended data retention · Direct engineering access

No white-label PDFs, priority generation/support, team seats, REST API access, custom branding, bulk CSV upload, account managers, SLAs, on-premise, or phone support are claimed anywhere in the product or docs.

4.9 Admin Panel

Feature	Files	Notes
User management table	<code>frontend/src/app/dashboard/admin/users/page.jsx</code> , <code>components/admin/UserManagementTable.jsx</code> (search/filter tabs/pagination, role pill dropdown, ban/unban), <code>useUserManagement.js</code>	Null-safe <code>isActive !== false</code> everywhere (d6ec97d)
User detail modal	<code>components/admin/UserDetailModal.jsx</code>	<code>GET /api/admin/users/{id}</code>
Ban/unban + role management	<code>adminService.js</code> (<code>banUser/unbanUser/updateUserRole</code>)	<code>PUT /api/admin/users/{id}/ban unban role</code>
Analytics	<code>frontend/src/app/dashboard/admin/analytics/page.jsx</code> , <code>components/admin/*</code> (KpiGrid, TopCitiesBar, RiskDistributionPie, ReportsLineChart, UserActivityHeatmap, DateRangePicker, ExportAnalyticsButton, ActiveUsersCounter)	recharts; Excel/PDF export of analytics
System settings/health	<code>frontend/src/app/dashboard/admin/system/page.jsx</code> (SystemHealthWidget), <code>frontend/src/app/dashboard/system-health/page.jsx</code> (AdminGuard; <code>/api/health/integrations</code>)	—
Audit logs	<code>frontend/src/app/dashboard/audit-logs/page.jsx</code> (ADMIN-only), <code>components/audit/*</code> (table, filters, detail modal, timeline, activity graph, CSV export)	<code>GET /api/audit-logs*</code>
Admin dashboard	<code>frontend/src/app/dashboard/admin/page.jsx</code> + <code>useAdminDashboard</code>	<code>/dashboard</code> auto-redirects ADMINS to <code>/dashboard/admin</code>

4.10 UX Polish

- **Framer Motion** across 47 files: modals (`AnimatePresence`), `RiskSpectrum` spring gauge, `CountUp`, `CardHover`, `FraudAlertBadge` pulse, landing parallax.
- **Confetti** (`canvas-confetti`) on payment success, report completion, account actions (`frontend/src/lib/celebrate.js`).
- **Sonner toasts** for all API feedback (bottom-right, dark, outside providers).
- **Skeletons** (`components/ui/Skeleton.jsx` + named skeletons) during every fetch.
- **ErrorBoundary** (`components/ErrorBoundary.jsx`, class-based) + 404 page (`app/not-found.js`).
- **Empty states** (`components/ui/EmptyState.jsx`, `NotificationEmpty`, `ReportHistoryEmpty`, `RiskHistoryEmpty`).

- **TopLoader** (nextjs-toploader, #22C55E 3 px bar) on route changes.

5. Database Schema

PostgreSQL 16. Managed by Hibernate `spring.jpa.hibernate.ddl-auto=update` (no Flyway dependency wired; `db/migration/*.sql` are manual artifacts). Seeding via `config/DataInitializer.java` (5 roles + 1 admin, idempotent, repairs wrong admin roles). All entities under `backend/src/main/java/com/realestate/duediligence/entity/`.

5.1 Tables (entity → table → columns)

User → users

Column	Type	Constraints	Notes
id	Long	PK, IDENTITY	—
full_name	String	NOT NULL	—
email	String	NOT NULL, UNIQUE	login identifier
password	String	nullable	BCrypt; NULL for Google-only
phone_number	String	nullable	—
role_id	FK	NOT NULL → roles.id, @ManyToOne EAGER	—
created_at / updated_at	LocalDateTime	—	—
reset_otp	String(6)	—	reset OTP (plain at rest)
reset_otp_expiry	LocalDateTime	—	10-min TTL
google_id	String	UNIQUE, nullable	Google sub claim
auth_provider	String(20)	—	LOCAL / GOOGLE / LOCAL_AND_GOOGLE
profile_picture	String(500)	—	—
token_valid_from	LocalDateTime	—	"logout all devices" cutoff
is_active	Boolean	NOT NULL, default true (V11)	NULL treated as active in code
is_banned	Boolean	default false	—

Relationships: @OneToMany(mappedBy="generatedBy", cascade=ALL, orphanRemoval=true, LAZY) reports.

Role → roles: id PK · role_name @Enumerated(STRING) RoleType NOT NULL UNIQUE.

PendingRegistration → pending_registrations (indexes: email UNIQUE, otp_expires_at): id PK · email NOT NULL UNIQUE(255) · full_name NOT NULL(100) · password_hash NOT NULL(255, BCrypt) · phone_number (20) · role enum STRING NOT NULL(50) · otp_hash NOT NULL(255, BCrypt) · otp_expires_at NOT NULL · verify_attempts int NOT NULL · resend_count int NOT NULL · last_resend_at · created_at NOT NULL.

Property → properties (indexes: created_by, city, verified, property_type, zip_code): id PK · address NOT NULL · city NOT NULL · state · zip_code · propertyType · area Double · marketValue Double · year_built Integer · lot_size Double · zoning · image_url String(500) · verified Boolean default false · bedrooms/bathrooms/stories Integer · structure_type · condition · created_by FK → users (@ManyToOne LAZY, @OnDelete CASCADE) · latitude/longitude Double · created_at/updated_at (@PrePersist/@PreUpdate). Relationships (cascade=ALL, orphanRemoval=true, LAZY): riskAssessments, reports, comparableAnalyses, valuations.

DueDiligenceReport → due_diligence_reports (indexes: property_id, generated_by, status, share_token UNIQUE, created_at): id PK · property_id FK NOT NULL (CASCADE) · generated_by FK NOT NULL (CASCADE) · risk_assessment_id FK nullable (snapshot) · title NOT NULL(300) · status enum STRING NOT NULL(20) default PENDING · version Integer NOT NULL default 1 · share_token String(100) UNIQUE (UUID) · share_expires_at · risk_score_snapshot Double · executive_summary (4000) · error_message (1000) · completed_at · created_at NOT NULL · updated_at · ai_summary TEXT · ai_summary_generated_at. Relationship: @OneToMany(mappedBy="report", cascade=ALL, orphanRemoval=true, @OrderBy("orderIndex ASC")) sections.

ReportSection → report_sections (indexes: report_id, section_type): id PK · report_id FK NOT NULL (CASCADE) · section_type NOT NULL(50) · title NOT NULL(300) · order_index Integer NOT NULL · content @Lob TEXT · data_json @Lob TEXT · created_at NOT NULL.

ReportHistory → **report_history** (legacy): **id** PK · **report_id** String NOT NULL · **property_id** FK NOT NULL (EAGER) · **user_id** FK nullable (EAGER) · **version** Integer · **risk_level** String · **file_path** · **is_archived** Boolean · **created_at**.

RiskAssessment → **risk_assessments** (indexes: property_id, overall_level, calculated_at): **id** PK · **property_id** FK NOT NULL (CASCADE) · **overall_score** Double NOT NULL (0–100) · **overall_level** enum STRING NOT NULL(20) · **flood_score/legal_score/tax_score/zoning_score/environmental_score/market_score** Double · **summary** (2000) · **is_latest** Boolean NOT NULL default true · **calculated_at** NOT NULL · **updated_at**. Relationship: @OneToMany(mappedBy="riskAssessment", cascade=ALL, orphanRemoval=true) **factors**.

RiskFactor → **risk_factors** (indexes: assessment_id, category): **id** PK · **assessment_id** FK NOT NULL (CASCADE) · **category** enum STRING NOT NULL(30) · **score** Double NOT NULL · **level** enum STRING NOT NULL(20) · **weight** Double NOT NULL · **explanation** (1000) · **recommendation** (1000) · **data_source** (200) · **created_at** NOT NULL.

AuditLog → **audit_logs**: **id** PK · **user_id** FK nullable (EAGER) · **action** enum STRING NOT NULL · **resource_type** String · **resource_id** Long · **details_json** TEXT · **ip_address** · **user_agent** (500) · **created_at**.

ComparableAnalysis → **comparable_analyses** (index: property_id): **id** PK · **property_id** FK NOT NULL · **radius_km** Double NOT NULL · **created_at** · @OneToMany(mappedBy="analysis", cascade=ALL, orphanRemoval=true) **comparableProperties**.

ComparableProperty → **comparable_properties** (indexes: analysis_id, comp_property_id): **id** PK · **analysis_id** FK NOT NULL · **comp_property_id** FK NOT NULL → **properties** · **similarity_score** Double · **similarity_level** enum STRING · **distance_km** Double.

ContactMessage → **contact_messages**: **id** PK · **name** NOT NULL(100) · **email** NOT NULL(255) · **company** (150) · **topic** NOT NULL(30) · **message** NOT NULL(3000) · **created_at** NOT NULL.

ExportHistory → **export_history**: **id** PK · **report_id** String · **user_id** Long NOT NULL · **format** String NOT NULL · **file_path** (500) · **file_size_bytes** Long · **created_at** NOT NULL · **download_count** Integer NOT NULL default 0.

Notification → **notifications** (indexes: (user_id,is_read), (user_id,created_at), notification_type): **id** PK · **user_id** FK NOT NULL (CASCADE, LAZY) · **notification_type** enum STRING NOT NULL(30) · **title** NOT NULL(255) · **message** NOT NULL TEXT · **redirect_url** (500) · **is_read** boolean NOT NULL default false · **created_at** NOT NULL (updatable=false).

NotificationPreference → **notification_preferences**: **id** PK · **user_id** FK UNIQUE NOT NULL (@OneToOne LAZY) · 8 booleans NOT NULL with defaults: **report_ready_email** =T, **report_ready_in_app** =T, **risk_alert_email** =T, **risk_alert_in_app** =T, **price_change_email** =F, **price_change_in_app** =T, **system_email** =T, **system_in_app** =T.

PortfolioSnapshot → **portfolio_snapshots** (indexes: user_id, snapshot_date, (user_id,snapshot_date)): **id** PK · **snapshot_date** LocalDate NOT NULL · **total_value** Double NOT NULL · **property_count** Integer NOT NULL · **verified_count** Integer NOT NULL · **total_cities** Integer NOT NULL · **user_id** FK **nullable** (null = platform aggregate) · **created_at**.

PropertyDueDiligenceSnapshot → **property_due_diligence_snapshots**: **id** PK · **property_id** FK NOT NULL · **ownership_json/tax_history_json/zoning_json/flood_zone_json/permits_json/environmental_json** TEXT · **overall_status** String · **total_duration_ms** Long · **aggregated_at** Instant · **created_at** Instant.

PropertyLabel → **property_labels** (UNIQUE (property_id, type)): **id** PK · **property_id** FK NOT NULL · **type** enum STRING NOT NULL(30) · **source** enum STRING NOT NULL(10) · **created_at** NOT NULL · **expires_at** · **created_by** Long.

PropertyValuation → **property_valuations** (index: property_id): **id** PK · **property_id** FK NOT NULL · **estimated_value** Double NOT NULL · **confidence_low/confidence_high** Double · **method** enum STRING NOT NULL · **calculated_at**.

SavedComparison → **saved_comparisons** (index: user_id): **id** PK · **user_id** FK NOT NULL (CASCADE) · **name** NOT NULL(100) · **notes** (1000) · **property_ids** String NOT NULL(255) · **created_at** NOT NULL (updatable=false) · **updated_at** NOT NULL.

Subscription → **subscriptions** (indexes: user_id, status): **id** PK · **user_id** Long NOT NULL (plain column) · **plan** enum STRING NOT NULL(20) · **status** String NOT NULL(20) (ACTIVE/CANCELLED/EXPIRED/FAILED) · **cashfree_order_id** (100) · **cashfree_payment_id** (100) · **amount** Long NOT NULL · **currency** (10) NOT NULL default "INR" · **created_at** NOT NULL · **expires_at** · **cancelled_at**.

5.2 Key relationships (foreign keys)

users.role_id → **roles.id** · **properties.created_by** → **users.id** (ON DELETE CASCADE) · **due_diligence_reports.property_id** → **properties.id** (CASCADE) · **due_diligence_reports.generated_by** → **users.id** (CASCADE) · **due_diligence_reports.risk_assessment_id** → **risk_assessments.id** · **report_sections.report_id** → **due_diligence_reports.id** (CASCADE) · **risk_assessments.property_id** → **properties.id** (CASCADE) · **risk_factors.assessment_id** → **risk_assessments.id** (CASCADE) · **audit_logs.user_id** → **users.id**.

comparable_analyses.property_id → properties.id · comparable_properties.analysis_id → comparable_analyses.id , comp_property_id → properties.id · notifications.user_id → users.id (CASCADE) · notification_preferences.user_id → users.id (1:1) · portfolio_snapshots.user_id → users.id (nullable) · property_due_diligence_snapshots.property_id → properties.id · property_labels.property_id → properties.id · property_valuations.property_id → properties.id · saved_comparisons.user_id → users.id (CASCADE) · report_history.property_id → properties.id , user_id → users.id .

5.3 Enums (enums/ package)

Enum	Values / data
RoleType	BUYER, REAL_ESTATE_AGENT, LEGAL_REVIEWER, FINANCIAL_INSTITUTION, ADMIN
AuditAction	LOGIN, LOGOUT, PROPERTY_VIEW, PROPERTY_CREATED, PROPERTY_UPDATED, PROPERTY_DELETED, REPORT_GENERATED, REPORT_DOWNLOADED, RISK_ASSESSED, EXPORT_PDF, EXPORT_EXCEL, USER_REGISTERED, PROFILE_UPDATED, PASSWORD_CHANGED
RiskCategory (with weights)	FLOOD 0.25, LEGAL 0.20, TAX 0.15, ZONING 0.15, ENVIRONMENTAL 0.15, MARKET 0.10
RiskLevel	LOW, MEDIUM, HIGH, CRITICAL — fromScore() : ≤25 LOW, ≤50 MEDIUM, ≤75 HIGH, else CRITICAL
ReportStatus	PENDING, GENERATING, COMPLETED, FAILED, ARCHIVED
SubscriptionPlan	FREE(0 paise, 3 reports/mo), PRO(49900 = ₹499/mo, unlimited), BUSINESS(199900 = ₹1,999/mo, unlimited), ENTERPRISE(0, unlimited)
LabelType / LabelSource	NEW, HOT, PRICE_DROP, FEATURED, VERIFIED, SOLD, UNDER_OFFER, PREMIUM / AUTO, MANUAL
NotificationType / NotificationChannel	REPORT_READY, RISK_ALERT, PRICE_CHANGE, SYSTEM / IN_APP, EMAIL, PUSH
SimilarityLevel	VERY_SIMILAR, SIMILAR, SOMEWHAT_SIMILAR
ValuationMethod	COMPARABLE, COST, INCOME
IntegrationStatus	LIVE, CACHED, MOCK, NO_DATA, UNAVAILABLE, TIMEOUT, ERROR

5.4 Scheduled maintenance

- scheduled/PendingRegistrationCleanupJob — deletes pending registrations older than 24 h.
- scheduled/PropertyLabelAutoUpdateJob — hourly cron (0 0 * * *) auto-label recalculation.
- PortfolioSnapshotServiceImpl — daily portfolio snapshots (seeded on startup, 27 users snapshotted on last boot).

6. API Endpoints

All endpoints are under the Next.js proxy (/api/* → backend). Auth = Authorization: Bearer <jwt> unless noted. Errors are uniform JSON (GlobalExceptionHandler): 400 validation/argument, 401 auth, 403 access denied, 404 not found, 429 rate-limited, 500 runtime. Auth requirements below are enforced by SecurityConfig matchers and/or @PreAuthorize .

6.1 Auth — AuthController (/api/auth)

Method	Path	Auth	Request	Response
POST	/api/auth/register/send-otp	permitAll	SendRegistrationOtpRequest	SendOtpResponse
POST	/api/auth/register/verify-otp	permitAll	VerifyRegistrationOtpRequest	AuthResponse
POST	/api/auth/register/resend-otp	permitAll	ResendRegistrationOtpRequest	SendOtpResponse
POST	/api/auth/login	permitAll	LoginRequest	AuthResponse
POST	/api/auth/google	permitAll	GoogleLoginRequest	GoogleAuthResponse
POST	/api/auth/complete-google-signup	permitAll	CompleteGoogleSignupRequest	AuthResponse
POST	/api/auth/forgot-password	permitAll	ForgotPasswordRequest	ApiResponse
POST	/api/auth/verify-otp	permitAll	VerifyOtpRequest	ApiResponse
POST	/api/auth/reset-password	permitAll	ResetPasswordRequest	ApiResponse

Method	Path	Auth	Request	Response
DELETE	/api/auth/account	authenticated	DeleteAccountRequest	ApiResponse
GET	/api/auth/me	authenticated	—	UserProfileResponse
PUT	/api/auth/me	authenticated	UpdateProfileRequest	UserProfileResponse
POST	/api/auth/change-password	authenticated	ChangePasswordRequest	ApiResponse
POST	/api/auth/logout-all-devices	authenticated	—	ApiResponse

6.2 Properties & property data

PropertyController (/api/properties) — GETs authenticated; writes `hasAnyRole( 'BUYER', 'REAL_ESTATE_AGENT', 'ADMIN' )`; admin endpoints `hasRole( 'ADMIN' )`.

Method	Path	Request	Response
POST	/api/properties	PropertyRequest (@Valid)	PropertyResponse
GET	/api/properties	—	List<PropertyResponse>
GET	/api/properties/{id}	—	PropertyResponse
GET	/api/properties/search?query=	—	List<PropertyResponse>
GET	/api/properties/recent	—	top 5 PropertyResponse
PUT	/api/properties/{id}	PropertyRequest	PropertyResponse
DELETE	/api/properties/{id}	—	204
POST	/api/properties/admin/reverify-all	—	Map (verifiedCount)
GET	/api/properties/geo	—	List<GeoPropertyResponse>
POST	/api/properties/admin/backfill-coordinates	—	Map (geocodedCount)

RiskAssessmentController (/api/properties/{propertyId}/risk*) — authenticated.

Method	Path	Response
GET	/risk	RiskAssessmentResponse (6 category scores, level, version, freshlyComputed)
GET	/risk/breakdown	RiskBreakdownDto (factors with weight/explanation/recommendation/dataSource)
GET	/risk/history	RiskHistoryDto (history, totalAssessments, scoreDelta, latestId)
POST	/risk/recalculate	RiskAssessmentResponse

PropertyAggregationController (aggregation/ package, /api/properties) — authenticated.

Method	Path	Response
GET	/api/properties/{id}/aggregated	AggregatedPropertyResponse (ownership/taxHistory/zoning/floodZone/permits/environmental IntegrationResponse<T> + overallStatus OK/PARTIAL/DEGRADED, 8 s SLA)
GET	/api/properties/{id}/snapshots	List<PropertyDueDiligenceSnapshot>

PropertyLabelController (/api) — GETs authenticated; writes ADMIN.

Method	Path	Request	Response
GET	/api/properties/{propertyId}/labels	—	List<PropertyLabelDto>
POST	/api/properties/{propertyId}/labels	AddLabelRequest	PropertyLabelDto
DELETE	/api/properties/{propertyId}/labels/{labelId}	—	Map
POST	/api/labels/recalculate-all	—	Map (propertiesProcessed)
POST	/api/labels/bulk	List<Long>	Map<Long, List<PropertyLabelDto>>

ComparablePropertyController (/api/properties) — GETs authenticated; POSTs `@PreAuthorize("isAuthenticated()")` (all roles).

Method	Path	Request	Response
GET	/api/properties/{id}/comparables?radius=&limit=	—	ComparableAnalysisResponse
GET	/api/properties/{id}/comparables/map-data?radius=	—	List<ComparablePropertyDto>
GET	/api/properties/{id}/comparables/{compId}/similarity	—	ComparablePropertyDto
POST	/api/properties/{id}/comparables/search	ComparableSearchRequest	ComparableAnalysisResponse
GET	/api/properties/{id}/comparables/price-trends	—	List<PriceTrendDto>
GET	/api/properties/{id}/valuation	—	PropertyValuationResponse
POST	/api/properties/{id}/valuation/calculate	—	PropertyValuationResponse
GET	/api/properties/{id}/valuation/methods-breakdown	—	ValuationBreakdownDto
GET	/api/properties/{id}/valuation/price-history	—	List<PropertyValuationResponse>

6.3 Reports & export

ReportController (/api/reports) — authenticated (ownership enforced in service).

Method	Path	Request	Response
POST	/api/reports/generate	GenerateReportRequest (@Valid: propertyId @NotNull, title ≤255, forceRiskRecalculation)	202 DueDiligenceReportResponse ; 402 on PlanLimitExceededException
GET	/api/reports/{reportId}/status	—	{reportId, status, isTerminal}
GET	/api/reports/{reportId}	—	DueDiligenceReportResponse (sections ordered)
GET	/api/reports?page=&size=&sortBy=&sortDir=	—	Page<ReportSummaryDto>
DELETE	/api/reports/{reportId}	—	204
GET	/api/reports/property/{propertyId}	—	List<ReportSummaryDto>
POST	/api/reports/{reportId}/regenerate	—	202 DueDiligenceReportResponse

ReportSummaryController (/api/reports) — authenticated: GET /api/reports/{id}/ai-summary → AiSummaryResponse {verdict, headline, keyPoints, recommendation, generatedAt, cached}; POST /api/reports/{id}/ai-summary/regenerate (429 if < 60 s since last).

ExportController (/api/export) — authenticated (/api/export/**).

Method	Path	Response
GET	/api/export/report/{reportId}/pdf	PDF bytes
GET	/api/export/report/{reportId}/excel	XLSX bytes
GET	/api/export/property/{propertyId}/pdf	PDF snapshot
GET	/api/export/property/{propertyId}/excel	XLSX snapshot
GET	/api/export/report/{reportId}/preview	ExportResponse
POST	/api/export/bulk (ExportRequest)	ZIP bytes
GET	/api/export/history?page=&size=	Page<ExportResponse>
GET	/api/export/{exportId}/download	PDF bytes (410 gone, 403, 404)

6.4 Dashboard & admin

DashboardController (/api/dashboard) — authenticated: GET /stats → DashboardStatsResponse; GET /insights → PortfolioInsightsResponse; GET /activity?limit= (1–30, default 10); GET /trends → DashboardTrendsResponse; GET /history?days= (1–365, default 30; admin gets platform aggregate); GET /recommendations → List<RecommendationResponse>.

Legacy role stubs: AgentController GET /api/agent/dashboard ("Welcome Real Estate Agent!", REAL_ESTATE_AGENT) · BuyerController GET /api/buyer/dashboard ("Welcome Buyer!", BUYER) · AdminController GET /api/admin/dashboard (ADMIN, @PreAuthorize, returns user count) · TestController GET /api/test (ADMIN, "JWT Authentication Successful!").

AdminDashboardController (`/api/admin/dashboard`) — ADMIN: `GET /stats?period=` (default 30d) → `DashboardStatsDto` ; `GET /export?format=excel|pdf|csv&period=&language=` → `byte[]` attachment; `GET /risk-distribution?period=` ; `GET /reports-trend?period=&granularity=` ; `GET /top-cities?limit=` (default 10); `GET /user-activity-heatmap` ; `GET /active-users?periodDays=` (default 30).

UserManagementController (`/api/admin`) — ADMIN:

Method	Path	Request	Response
GET	<code>/api/admin/users?page=&size=&search=&role=</code>	—	<code>Page<UserManagementDto></code>
GET	<code>/api/admin/users/{userId}</code>	—	<code>UserManagementDto</code>
PUT	<code>/api/admin/users/{userId}/role</code>	<code>UpdateUserRoleRequest {role}</code>	<code>UserManagementDto</code>
PUT	<code>/api/admin/users/{userId}/ban</code>	—	<code>UserManagementDto</code>
PUT	<code>/api/admin/users/{userId}/unban</code>	—	<code>UserManagementDto</code>
GET	<code>/api/admin/system/health</code>	—	<code>SystemHealthDto {dbStatus, apiStatus, uptimeSeconds}</code>

AuditLogController (`/api/audit-logs`) — ADMIN only (class-level `@PreAuthorize("hasRole('ADMIN')")`): `GET /api/audit-logs?page=&size=&action=&userId=&from=&to=` ; `GET /{id}` ; `GET /user/{userId}` ; `GET /property/{propertyId}` ; `GET /export?format=csv` (`byte[]`); `GET /stats`.

HealthCheckController (`/api/health`) — `GET /api/health/integrations` `@PreAuthorize("hasRole('ADMIN')")` → `List<IntegrationHealthStatus>` (WAQI, Nominatim, GoogleOAuth).

6.5 Notifications & SSE

NotificationController (`/api/notifications`) — authenticated (`send-bulk` ADMIN).

Method	Path	Request	Response
GET	<code>/api/notifications?page=&size=&unread=&type=</code>	—	<code>Page<NotificationDto></code>
GET	<code>/api/notifications/unread-count</code>	—	<code>NotificationCountDto</code>
PUT	<code>/api/notifications/{id}/read</code>	—	204/404
PUT	<code>/api/notifications/mark-all-read</code>	—	<code>Map</code>
DELETE	<code>/api/notifications/{id}</code>	—	204/404
DELETE	<code>/api/notifications/clear-all</code>	—	<code>Map</code>
GET/PUT	<code>/api/notifications/preferences</code>	<code>UpdatePreferencesRequest</code> (8 booleans)	<code>NotificationPreferenceDto</code>
POST	<code>/api/notifications/test</code>	—	<code>NotificationDto</code>
POST	<code>/api/notifications/send-bulk</code>	<code>{title, message}</code>	<code>Map</code>

SseController (`/api/sse`) — `permitAll` in matchers, manual `SecurityContext` check (401 if anonymous): `GET /api/sse/notifications` → `SseEmitter` (30-min timeout, initial `ping`, `Cache-Control: no-cache`, `X-Accel-Buffering: no`).

6.6 Subscriptions — **SubscriptionController** (`/api/subscription`)

Method	Path	Auth	Notes
POST	<code>/api/subscription/create-order</code>	authenticated	<code>CreateOrderRequest {plan}</code> ("pro"/"business"); rejects FREE/ENTERPRISE; 502 on gateway failure
POST	<code>/api/subscription/webhook</code>	<code>permitAll</code> (HMAC-verified)	raw body + <code>x-webhook-signature</code> ; activates on PAYMENT_SUCCESS_WEBHOOK + PAID
GET	<code>/api/subscription/current</code>	authenticated	plan, planLimit, reportsThisMonth, reportsRemaining (−1 = unlimited), expiresAt, status
GET	<code>/api/subscription/verify-order?orderId=</code>	authenticated	PAID/PENDING (polled by checkout page)
POST	<code>/api/subscription/cancel</code>	authenticated	status → CANCELLED

6.7 AI chat — `AgentChatController` (`/api/agent`) — authenticated (any role)

`POST /api/agent/chat/stream` (`text/event-stream`) — body `ChatRequest(Long propertyId, String question, List<MessageDto> history)` → `SseEmitter(300 s)`; each token Base64-encoded per event; errors streamed as `[Error: ...]`.

6.8 Comparisons & contact

`SavedComparisonController` (`/api/comparisons`) — `@PreAuthorize("isAuthenticated()")` (all roles): `POST /` (`SavedComparisonRequest {name @NotBlank 3–100, notes ≤1000, propertyIds @NotEmpty 2–3}`) → 201; `GET /`; `GET /{id}`; `PATCH /{id}`; `DELETE /{id}` — all wrap `Map(success, message, data)`.

`ContactController` (`/api/contact`) — `POST /api/contact/submit` `permitAll`, `@Valid ContactSubmitRequest {name, email, company, topic, message ≤3000}` → persists `ContactMessage` + emails inbox & auto-reply.

6.9 Key request-validation rules (Jakarta Bean Validation)

`LoginRequest` `email @NotBlank @Email` + `password @NotBlank` · `RegisterRequest` / `SendRegistrationOtpRequest` `fullName @Size(3–100)`, `password @Size(8–20)`, `phoneNumber @Pattern(^[6-9]\d{9}$)`, `role @NotNull` · OTP fields `@Pattern(^\d{6}$)` · `CompleteGoogleSignupRequest` `credential @NotBlank` + `phone pattern` · `ChangePasswordRequest` `newPassword @Size(8–20) @Pattern(^(?=.*[A-Za-z])(?=.*\d).+$)` · `UpdateProfileRequest` all optional (`fullName @Size(3–100)`, `phone pattern`, `profilePicture ≤500`) · `PropertyRequest` `address @Size(6–255)`, `city @Size(2–100)`, `zip @Pattern(^\d{5,6}$|^$)`, `area/marketValue @Positive` · `GenerateReportRequest` `propertyId @NotNull` · `ContactSubmitRequest` `message @Size(max 3000)`.

6.10 Rate limits (Bucket4j, per IP, in-memory)

Endpoint	Limit
<code>/api/auth/login</code> , <code>/api/auth/google</code>	5 / minute
<code>/api/auth/forgot-password</code>	3 / hour
<code>/api/auth/register/send-otp</code> , <code>/resend-otp</code>	10 / hour
OTP verify + reset-password	10 / 10 minutes
<code>/api/export/**</code> (any method)	30 / minute

Exceed → 429 + `Retry-After` header + JSON message.

7. Frontend Pages & Routes

Next.js 16 App Router under `frontend/src/app/`. All pages are "use client" unless noted. Guards: `AuthGuard` wraps all of `/dashboard/*` (via `dashboard/layout.js`); `GuestGuard` on login/register; `AdminGuard` only on `/dashboard/system-health` · `/reports/*` and `/properties/*` rely on API 401 handling. **No `middleware.ts`** — `AuthGuard` replaced it (Next 16 Turbopack broke `proxy.ts` redirects).

Public marketing

Route	Page file	Purpose
<code>/</code>	<code>page.js</code>	LandingPage (hero, features, testimonials, pricing teaser)
<code>/pricing</code>	<code>pricing/page.js</code>	4 plans + FAQ
<code>/contact</code>	<code>contact/page.js</code>	Contact form + testimonials
<code>/privacy</code>	<code>privacy/page.js</code>	Privacy policy
<code>/terms</code>	<code>terms/page.js</code>	Terms of service
<code>/security</code>	<code>security/page.jsx</code>	Security page (server component)
<code>/docs</code> , <code>/docs/[slug]</code>	<code>docs/page.js</code> , <code>docs/[slug]/page.js</code>	Docs hub + article viewer
<code>/support</code>	<code>support/page.jsx</code>	FAQ + contact

Auth (guest)

Route	Page file	Purpose
<code>/login</code>	<code>login/page.js</code>	Login form + Google button, GuestGuard
<code>/register</code>	<code>register/page.js</code>	RegisterForm + OTP modal, GuestGuard
<code>/forgot-password</code>	<code>forgot-password/page.jsx</code>	4-step reset wizard
<code>/complete-profile</code>	<code>complete-profile/page.jsx</code>	Google signup step 2 (role + phone)

Checkout

Route	Page file	Purpose
<code>/checkout</code>	<code>checkout/page.js</code>	Cashfree order creation
<code>/checkout/success</code>	<code>checkout/success/page.js</code>	Poll verify-order + confetti

Dashboard (AuthGuard-protected)

Route	Page file	Purpose
<code>/dashboard</code>	<code>dashboard/page.js</code>	Portfolio home (KPIs, charts, map, activity) — ADMINS redirected to <code>/dashboard/admin</code>
<code>/dashboard/admin</code>	<code>dashboard/admin/page.jsx</code>	Admin dashboard (KPIs, charts, heatmap, export)
<code>/dashboard/admin/users</code>	<code>dashboard/admin/users/page.jsx</code>	User management
<code>/dashboard/admin/analytics</code>	<code>dashboard/admin/analytics/page.jsx</code>	Analytics charts
<code>/dashboard/admin/system</code>	<code>dashboard/admin/system/page.jsx</code>	System health
<code>/dashboard/audit-logs</code>	<code>dashboard/audit-logs/page.jsx</code>	ADMIN-only audit explorer
<code>/dashboard/billing</code>	<code>dashboard/billing/page.js</code>	Subscription management
<code>/dashboard/due-diligence</code>	<code>dashboard/due-diligence/page.jsx</code>	All-property report center
<code>/dashboard/notifications</code>	<code>dashboard/notifications/page.js</code>	Notification center
<code>/dashboard/profile</code>	<code>dashboard/profile/page.js</code>	Profile, password, delete, sign-out-all
<code>/dashboard/property-comparison</code>	<code>dashboard/property-comparison/page.jsx</code>	Compare up to 3 properties
<code>/dashboard/property-search</code>	<code>dashboard/property-search/page.js</code>	Search + filters + compare tray
<code>/dashboard/property-search/[id]</code>	<code>dashboard/property-search/[id]/page.js</code>	Property detail + AI assistant FAB
<code>/dashboard/report-history</code>	<code>dashboard/report-history/page.jsx</code>	Report history
<code>/dashboard/risk-assessment</code>	<code>dashboard/risk-assessment/page.jsx</code>	Risk workbench
<code>/dashboard/saved-comparisons</code>	<code>dashboard/saved-comparisons/page.jsx</code>	Saved comparisons
<code>/dashboard/settings</code>	<code>dashboard/settings/page.js</code>	Language + notification preferences
<code>/dashboard/system-health</code>	<code>dashboard/system-health/page.jsx</code>	AdminGuard; integration health

Standalone (API-guarded)

Route	Page file	Purpose
<code>/reports</code>	<code>reports/page.jsx</code>	My Reports (paginated, sortable, filterable)
<code>/reports/[reportId]</code>	<code>reports/[reportId]/page.jsx</code>	Report viewer (TOC, AI summary, exports)
<code>/reports/[reportId]/print</code>	<code>reports/[reportId]/print/page.jsx</code>	Print view
<code>/reports/export-history</code>	<code>reports/export-history/page.jsx</code>	Export history
<code>/properties/[id]/comparables</code>	<code>properties/[id]/comparables/page.jsx</code>	Comparables (Leaflet map)
<code>/properties/[id]/generate-report</code>	<code>properties/[id]/generate-report/page.jsx</code>	Report generation
<code>/properties/[id]/risk-analysis</code>	<code>properties/[id]/risk-analysis/page.jsx</code>	Risk analysis
<code>/properties/[id]/valuation</code>	<code>properties/[id]/valuation/page.jsx</code>	Valuation

8. Security Measures

Measure	Implementation
JWT authentication	HS256 (<code>JwtService</code>), 1 h expiry, secret from <code>JWT_SECRET</code> env (75-char min recommended); <code>extractIssuedAt</code> used for session invalidation
Session invalidation	<code>users.token_valid_from</code> — tokens with <code>iat</code> before it are rejected (<code>JwtAuthenticationFilter</code>)
Password hashing	BCrypt (<code>BCryptPasswordEncoder</code> , strength 10); OTPs BCrypt-hashed at rest; passwords hashed on the pending-registration row and never re-hashed
Google OAuth verification	Server-side <code>GoogleIdTokenVerifier</code> (signature + audience + expiry) — client tokens never trusted blindly
Role-based endpoint protection	<code>SecurityConfig</code> matchers: <code>/api/admin/**</code> ADMIN, <code>/api/buyer/**</code> BUYER, <code>/api/legal/**</code> LEGAL_REVIEWER, <code>/api/financial/**</code> FINANCIAL_INSTITUTION, <code>/api/agent/**</code> REAL_ESTATE_AGENT (chat sub-path open to all authenticated); admin bypass for downloads
CORS	Explicit allowlist (<code>http://localhost:3000</code> , <code>http://localhost:3001</code>); production avoids CORS entirely via same-origin proxy
CSRF	Stateless JWT + same-origin proxy; CSRF disabled in Spring config, mitigated by SameSite=Strict cookies
Input validation	Jakarta Bean Validation (<code>@Valid</code> + <code>@NotBlank</code> /field constraints) on every DTO; <code>MethodArgumentNotValidException</code> → 400 with field errors
SQL injection	Spring Data JPA parameterized queries exclusively; admin search uses <code>@Param</code> bindings; native heatmap query has no user input
XSS	React auto-escaping; markdown in chat via react-markdown; CSP header allows only self + <code>blob:</code> images/scripts + <code>accounts.google.com</code> + <code>api.groq.com</code>
Security headers	<code>SecurityConfig</code> : frame DENY, nosniff, HSTS, <code>Referrer-Policy: strict-origin-when-cross-origin</code> , CSP; Vercel adds <code>X-Frame-Options</code> , <code>X-Content-Type-Options</code> , <code>Referrer-Policy</code> , <code>Permissions-Policy</code>
Rate limiting	Bucket4j per-IP buckets (see §6.10), filter runs before Spring Security
Secrets	All secrets in <code>.env</code> files (gitignored), referenced as <code>\${ENV_VAR}</code> ; <code>ad56080</code> moved Cashfree + all secrets out of committed files; <code>.env.example</code> templates only
Error hygiene	<code>GlobalExceptionHandler</code> never leaks stack traces to clients; uniform JSON error bodies
Audit trail	Every sensitive action logged to <code>audit_logs</code> with IP + user-agent (<code>saveAuditLog</code>); viewable by ADMIN only (class-level <code>@PreAuthorize("hasRole('ADMIN')")</code> on <code>AuditLogController</code>)
Webhook verification	Cashfree: HmacSHA256(raw body, webhook secret) vs <code>x-webhook-signature</code> header
Admin seeding	<code>DataInitializer</code> seeds admin idempotently and repairs wrong roles back to ADMIN
Privacy	Account deletion (GDPR/DPDP): type “DELETE” + password/email confirmation, cascade delete, farewell email; GA4 consent gate (opt-in analytics, anonymize_ip, cookie deletion on reject)
RBAC — backend	<code>RoleUtils</code> shared helper (<code>isAdmin</code> , <code>isPaidProfessionalRole</code> , <code>canViewAllProperties</code> , <code>canAccessProperty</code>); <code>@PreAuthorize</code> on all sensitive controllers (admin/audit/health/test); service-layer owner-or-view-all checks on every property/report/risk/comparable/valuation/AI-summary read; report deletion blocked for LEGAL/FIN (403); plan limits bypassed for ADMIN + pro roles
RBAC — frontend	<code>AuthGuard</code> blocks unauthenticated routes and redirects LEGAL/FIN away from <code>/dashboard/billing</code> + <code>/checkout</code> (with toast); <code>Sidebar</code> hides billing for pro roles and shows the admin platform menu (incl. Property Search); <code>Navbar</code> hides Upgrade/plan badge; <code>CommandPalette</code> filters add-property; Edit/Delete/Delete-Report buttons hidden per role. Note: no <code>middleware.ts</code> — <code>AuthGuard</code> is the route guard
JWT fail-fast	Missing <code>JWT_SECRET</code> fails at startup instead of producing runtime 500s; 75-char secret in <code>backend/.env</code>
Session invalidation	<code>token_valid_from</code> timestamp (logout-all-devices): tokens with <code>iat</code> before it are rejected as <code>SESSION_INVALIDATED</code>

9. Testing

9.1 Backend — 58 tests (JUnit 5 + Mockito + AssertJ + H2)

Confirmed via surefire reports: **58 tests, 0 failures, 0 errors, 0 skipped** across 13 classes. (A 14th class

`DueDiligenceAgentApplicationTests.contextLoads` exists in source but is not in the last run's reports.)

Class	Tests	What it verifies
<code>controller/ExportControllerTest</code>	3	PDF/Excel 200 with content; 500 on invalid report id
<code>controller/ReportControllerTest</code>	6	generate 202, list page, get body, delete 204, 400 invalid body, 401 unauthenticated
<code>controller/RiskAssessmentControllerTest</code>	5	risk 200, 401, history 200, 404, breakdown 200
<code>integration/EndToEndWorkflowTest</code>	1	full OTP register → verify → login over real HTTP (RANDOM_PORT)
<code>integration/FullReportFlowIT</code>	2	full property report flow; register+login+reports with JWT (H2, <code>test</code> profile)
<code>integration/NominatimIntegrationTest</code>	1	live Nominatim health check
<code>integration/WAQIIntegrationTest</code>	1	live WAQI health check
<code>service/impl/ChartGeneratorImplTest</code>	6	risk gauge (4 levels), bar chart, donut chart
<code>service/impl/DueDiligenceReportServiceImplTest</code>	7	generate/status/fetch/delete ownership rules, auth required
<code>service/impl/ExcelExportServiceImplTest</code>	5	3-sheet XLSX, headers, factor rows
<code>service/impl/PdfExportServiceImplTest</code>	5	PDF bytes, renderer failure resilience
<code>service/impl/PropertyServiceImplTest</code>	8	CRUD + ownership scoping + search
<code>service/impl/RiskAssessmentServiceImplTest</code>	8	compute/persist/latest/delta/null-scores/history

Infrastructure: `@WebMvcTest` slices with `@MockitoBean` + a `@TestConfiguration` wiring the real `JwtAuthenticationFilter` + `RateLimitFilter`; `@Mock` / `@InjectMocks` unit tests with `mockStatic(TransactionSynchronizationManager)` to neutralize after-commit hooks.

Test config (`src/test/resources/application-test.yml`): H2 in-memory (`MODE=PostgreSQL;DB_CLOSE_DELAY=-1`), `ddl-auto: create-drop`, mail disabled, deterministic 64-byte JWT secret, dummy integration keys. **JaCoCo 0.8.12** reports to `target/site/jacoco` (no `check` thresholds configured; README cites 33.8% line / 15.7% branch).

9.2 Frontend — 33 tests (Vitest + Testing Library)

Group	File	Tests
utils	<code>__tests__/utils/currency.test.js</code>	5 (INR formats, lakh/crore, zero/invalid, negatives/full)
utils	<code>__tests__/utils/helpers.test.js</code>	4 (isAuthenticated, removeToken, password strength)
utils	<code>__tests__/utils/riskUtils.test.js</code>	6 (score boundaries, edges, colors, high/critical detection)
hooks	<code>__tests__/hooks/useAgentChat.test.jsx</code>	3 (initial state, SSE streaming via stubbed fetch, auth error)
hooks	<code>__tests__/hooks/useRiskAssessment.test.jsx</code>	4 (loading, breakdown, error, history)
components	<code>__tests__/components/property/FraudAlertBadge.test.jsx</code>	3 (CRITICAL pulse, HIGH, MEDIUM hidden)
components	<code>__tests__/components/reports/AISummaryCard.test.jsx</code>	3 (loading, verdict, regenerate disabled)
components	<code>__tests__/components/risk/RiskSpectrum.test.jsx</code>	5 (2 it + it.each×3 rows + snapshot)

Setup (`vitest.config.js` + `src/test/setup.js`): jsdom, in-memory storage, mocked

`matchMedia` / `IntersectionObserver` / `ResizeObserver`, `next/navigation`, `next/link`, `react-i18next` (`t = key`), `sonner`, and a full framer-motion mock (Proxy → plain elements). `@testing-library/jest-dom` for matchers. Scripts: `npm run test:run` (CI), `test`, `test:ui`, `test:coverage`.

10. DevOps & Deployment

10.1 Docker (repo root)

File	Details
<code>Dockerfile.backend</code>	2 stages: <code>maven:3.9-eclipse-temurin-17-alpine</code> (offline deps + <code>mvn clean package -DskipTests</code>) → <code>eclipse-temurin:17-jre-alpine</code> ; non-root <code>spring</code> user; <code>JAVA_OPTS="-XX:+UseContainerSupport -XX:MaxRAMPercentage=75.0"</code> ; HEALTHCHECK <code>curl -f /actuator/health</code> (30s/5s/60s); ENTRYPOINT <code>java \$JAVA_OPTS -jar app.jar</code>
<code>Dockerfile.frontend</code>	3 stages: deps (<code>node:20-alpine</code> , <code>npm ci</code>) → builder (<code>ARG API_PROXY_URL=http://backend:8080</code> , <code>npm run build</code>) → runtime (<code>nextjs</code> user uid 1001, <code>.next/standalone</code> + static + public, <code>NODE_ENV=production</code> <code>PORT=3000</code> <code>HOSTNAME=0.0.0.0</code> , HEALTHCHECK <code>wget</code>)
<code>docker-compose.yml</code>	3 services on <code>dd-network</code> : <code>postgres</code> (16-alpine, volume <code>postgres_data</code> , <code>pg_isready</code> healthcheck), <code>backend</code> (depends on postgres healthy; <code>SPRING_PROFILES_ACTIVE=docker</code>), <code>frontend</code> (depends on backend healthy; <code>API_PROXY_URL=http://backend:8080</code>). Ports 5432/8080/3000. <code>restart: unless-stopped</code> .
<code>.dockerignore</code>	excludes node_modules, target, .env*, .git, docs, logs, Dockerfiles

10.2 CI/CD — `.github/workflows/ci.yml`

Single workflow `CI` on push/PR to `develop` + `main` , concurrency-cancelling:

- backend-tests:** Java 17 Temurin (Maven cache) → `mvn test -Dspring.profiles.active=test -B` → uploads JaCoCo artifact (`backend/target/site/jacoco/`) with `if: always()` .
- frontend-tests:** Node 20 → `npm ci` → `npm run test:run` (Vitest).
- docker-build:** needs both → builds `dd-backend:ci` + `dd-frontend:ci` (no push).

Deploys are handled by Vercel/Render auto-deploy on push.

10.3 Deployment (free tier)

Target	Config	Notes
Render (backend + DB)	<code>render.yaml</code> blueprint: <code>dd-backend</code> web service (Dockerfile.backend, region singapore, <code>healthCheckPath: /actuator/health</code> , auto-deploy) + <code>dd-postgres</code> (free, <code>duediligence</code> DB). <code>JWT_SECRET</code> auto-generated; secrets synced manually.	Render's <code>postgres://</code> URL must be converted to <code>jdbc:postgresql://...</code> manually. Free tier sleeps after 15 min idle (~30–60 s cold start).
Vercel (frontend)	<code>frontend/vercel.json</code> : framework nextjs, region <code>bom1</code> (Mumbai), <code>NEXT_PUBLIC_API_URL=https://dd-backend.onrender.com</code> , <code>/api/:path*</code> rewrite, security headers on <code>/(.*)</code> .	The rewrite host is the <code>YOUR-BACKEND.onrender.com</code> placeholder — replace after first Render deploy.
Alternative DB	Neon (Postgres) per <code>docs/DEPLOYMENT.md</code> — needs <code>?sslmode=require</code> in the JDBC URL	Render free DB expires after 30 days

10.4 Environment variables (names only)

Variable	Purpose
<code>JWT_SECRET</code>	HS256 signing secret (required — fail-fast)
<code>DB_PASSWORD</code> / <code>SPRING_DATASOURCE_URL USERNAME PASSWORD</code>	Postgres connectivity (local vs Docker/Render)
<code>SPRING_PROFILES_ACTIVE</code>	<code>docker</code> profile in containers
<code>GOOGLE_CLIENT_ID</code> / <code>GOOGLE_OAUTH_CLIENT_SECRET</code>	Google OAuth
<code>NEXT_PUBLIC_GOOGLE_CLIENT_ID</code>	GIS button client ID (frontend)
<code>GROQ_API_KEY</code>	Groq LLM
<code>CASHFREE_APP_ID</code> / <code>CASHFREE_SECRET_KEY</code> / <code>CASHFREE_ENV</code> / <code>CASHFREE_WEBHOOK_SECRET</code>	Cashfree gateway
<code>MAIL_USERNAME</code> / <code>MAIL_PASSWORD</code> / <code>MAIL_HOST</code> / <code>MAIL_PORT</code>	Gmail SMTP
<code>ADMIN_PASSWORD</code>	bootstrap admin seed
<code>WAQI_TOKEN</code>	WAQI air-quality API
<code>NEXT_PUBLIC_API_URL</code> / <code>API_PROXY_URL</code> / <code>NEXT_PUBLIC_BACKEND_URL</code>	backend base URL (frontend/SSE/chat)
<code>NEXT_PUBLIC_CLOUDINARY_CLOUD_NAME</code> / <code>NEXT_PUBLIC_CLOUDINARY_UPLOAD_PRESET</code>	image uploads
<code>NEXT_PUBLIC_GA4_MEASUREMENT_ID</code>	GA4 analytics (consent-gated)

Variable	Purpose
POSTGRES_DB / POSTGRES_USER / POSTGRES_PASSWORD	compose Postgres
JAVA_OPTS / NODE_ENV / PORT / HOSTNAME	runtime flags

Templates: `backend/.env.example` , `frontend/.env.example` , root `.env.docker.example` .

11. Project Structure

```

repo/
├── backend/                                Spring Boot 4.1 (Java 17, Maven)
│   ├── pom.xml
│   ├── mvnw / mvnw.cmd
│   └── src/main/java/com/realestate/duediligence/
│       ├── DueDiligenceAgentApplication.java (@SpringBootApplication @EnableAsync @EnableCaching @EnableRetry @EnableScheduling)
│       ├── actuator/                        CustomHealthIndicator (externalIntegrations aggregate)
│       ├── aggregation/                    PropertyAggregationController, PropertyAggregationService (8 s SLA, snapshot cache)
│       ├── config/                         AsyncConfig, DataInitializer, IntegrationConfig, JacksonConfig,
│       │                                       OpenApiConfig, PdfConfig, PdfDesignSystem, RiskScoringConfig
│       ├── controller/                     AuthController, AgentChatController, AgentController (stub), BuyerController (stub),
│       │                                       AdminController (stub), AdminDashboardController, AuditLogController,
│       │                                       ComparablePropertyController, ContactController, DashboardController,
│       │                                       ExportController, NotificationController, PropertyController,
│       │                                       PropertyLabelController, ReportController, ReportSummaryController,
│       │                                       RiskAssessmentController, SavedComparisonController, SseController,
│       │                                       SubscriptionController, TestController, UserManagementController
│       ├── dto/                             LoginRequest, SendRegistrationOtpRequest, VerifyRegistrationOtpRequest,
│       │                                       ResendRegistrationOtpRequest, GoogleLoginRequest, CompleteGoogleSignupRequest,
│       │                                       AuthResponse, GoogleAuthResponse, ApiResponse, SendOtpResponse,
│       │                                       UserProfileResponse, UpdateProfileRequest, ChangePasswordRequest,
│       │                                       DeleteAccountRequest, ForgotPasswordRequest, VerifyOtpRequest,
│       │                                       ResetPasswordRequest, PropertyRequest/Response, GeoPropertyResponse,
│       │                                       DueDiligenceReportResponse, ReportSummaryDto, ReportSectionDto,
│       │                                       AiSummaryResponse, RiskAssessmentResponse, RiskBreakdownDto,
│       │                                       RiskHistoryDto, RiskScoreResponse, ComparableAnalysisResponse,
│       │                                       ComparablePropertyDto, ComparableSearchRequest, PriceTrendDto,
│       │                                       PropertyValuationResponse, ValuationBreakdownDto,
│       │                                       DashboardStatsResponse, DashboardStatsDto, PortfolioInsightsResponse,
│       │                                       PortfolioHistoryPoint, DashboardTrendsResponse, RecommendationResponse,
│       │                                       ActivityItemResponse, CityActivityDto, MonthlyTrendDto,
│       │                                       RiskDistributionDto, UserActivityDto, UserManagementDto,
│       │                                       UpdateUserRoleRequest, SystemHealthDto, AuditLogDto/DetailDto,
│       │                                       NotificationDto, NotificationCountDto, NotificationPreferenceDto,
│       │                                       UpdatePreferencesRequest, ExportRequest/Response, CreateOrderRequest/Response,
│       │                                       SavedComparisonRequest/Response, PropertyLabelDto, AddLabelRequest,
│       │                                       AggregatedPropertyResponse, IntegrationHealthStatus, ReportHistoryDto,
│       │                                       ContactSubmitRequest, GenerateReportRequest, ...
│       ├── entity/                          User, Role, PendingRegistration, Property, DueDiligenceReport,
│       │                                       ReportSection, ReportHistory, RiskAssessment, RiskFactor, AuditLog,
│       │                                       ComparableAnalysis, ComparableProperty, ContactMessage, ExportHistory,
│       │                                       Notification, NotificationPreference, PortfolioSnapshot,
│       │                                       PropertyDueDiligenceSnapshot, PropertyLabel, PropertyValuation,
│       │                                       SavedComparison, Subscription
│       ├── enums/                           RoleType, AuditAction, LabelType, LabelSource, NotificationChannel,
│       │                                       NotificationType, ReportStatus, RiskCategory, RiskLevel,
│       │                                       SimilarityLevel, SubscriptionPlan, ValuationMethod
│       ├── exception/                       GlobalExceptionHandler, PlanLimitExceededException
│       ├── export/excel/                     ExcelStyleFactory
│       ├── integration/                     HealthCheckController, GoogleOAuthHealthCheck, NominatimHealthCheck,
│       │                                       WAQIHealthCheck, IntegrationHealthStatus,
│       │                                       common/ (IntegrationStatus, IntegrationResponse<T>,
│       │                                           PropertyInfoProvider<T>, IndianCityCatalog),
│       │                                       ownership|tax|zoning|flood|permit|environmental/ (records + providers),
│       │                                       impl/ (AddressValidationServiceImpl, GeocodingServiceImpl,
│       │                                           environmental/CpcbEnvironmentalProvider, Mock*Providers)
│       ├── pdf/                             util/ (HumanizeText, IndianNumberFormatter, PdfComponents,
│       │                                       PdfFontManager), renderer/ (7 SectionRenderers),
│       │                                       templates/pdf/ (CoverPageTemplate, RiskGaugeRenderer,
│       │                                           ChartImageRenderer, TableRenderer)
│       ├── repository/                      UserRepository, RoleRepository, PendingRegistrationRepository,
│       │                                       PropertyRepository, DueDiligenceReportRepository, ReportSectionRepository,
│       │                                       ReportHistoryRepository, RiskAssessmentRepository, RiskFactorRepository,
│       │                                       AuditLogRepository, ComparableAnalysisRepository, ContactMessageRepository,
│       │                                       ExportHistoryRepository, NotificationRepository,

```

```

NotificationPreferenceRepository, PortfolioSnapshotRepository,
PropertyDueDiligenceSnapshotRepository, PropertyLabelRepository,
PropertyValuationRepository, SavedComparisonRepository,
SubscriptionRepository
├── scheduled/ PendingRegistrationCleanupJob, PropertyLabelAutoUpdateJob
├── security/ SecurityConfig, JwtAuthenticationFilter, RateLimitFilter, RateLimitService
├── service/ AdminAnalyticsService, AdminExportService, AgentChatService,
AuditLogService, CashfreeService, ChartGenerator,
ComparablePropertyService, DashboardService, DueDiligenceReportService,
EmailService, ExcelExportService, ExportService, GeocodingService,
GoogleTokenVerifier, NotificationEventPublisher, NotificationEventListener,
NotificationService, PdfExportService, PdfReportDataProvider,
PortfolioSnapshotService, PropertyLabelService, PropertyService,
PropertyValuationService, PropertyVerificationService,
ReportHistoryService, ReportSummaryService, RiskAssessmentService,
RiskScoringEngine, SavedComparisonService, SystemHealthService, UserService
├── impl/ UserServiceImpl, CustomUserDetailsService, AgentChatServiceImpl,
ReportSummaryServiceImpl, CashfreeServiceImpl,
DueDiligenceReportServiceImpl, ReportGenerationExecutor,
ReportSectionBuilder, RiskAssessmentServiceImpl,
PropertyServiceImpl, PropertyValuationServiceImpl,
ComparablePropertyServiceImpl, DashboardServiceImpl,
PortfolioSnapshotServiceImpl, AuditLogServiceImpl,
AdminAnalyticsServiceImpl, AdminExportServiceImpl,
ExcelExportServiceImpl, PdfExportServiceImpl,
PdfReportDataProviderImpl, ChartGeneratorImpl, ExportServiceImpl,
GeocodingServiceImpl, NotificationServiceImpl,
PropertyLabelServiceImpl, ReportHistoryServiceImpl,
SavedComparisonServiceImpl, SystemHealthServiceImpl
├── util/ JwtService
├── resources/ application.properties, application-docker.properties,
db/migration/V10__add_subscriptions_table.sql, V11__fix_is_active.sql,
fonts/ (PDF fonts incl. Indic)
├── src/test/java/com/realestate/duediligence/ (13 test classes – see §9.1)
├── resources/application-test.yml

frontend/ Next.js 16 App Router (React 19, Tailwind v4)
├── package.json · next.config.mjs · vercel.json · vitest.config.js ·
├── jsconfig.json · components.json · postcss.config.mjs
├── public/ (og-image.png, favicon.ico)
├── src/
├── app/ layout.js, providers.jsx, globals.css, not-found.js,
page.js (landing), pricing/, contact/, privacy/, terms/, security/,
docs/, docs/[slug]/, support/, checkout/, checkout/success/,
login/, register/, forgot-password/, complete-profile/,
dashboard/ (19 routes incl. admin/users|analytics|system,
audit-logs, billing, notifications, profile,
property-search/[id], property-comparison,
due-diligence, report-history, risk-assessment,
saved-comparisons, settings, system-health),
reports/ (+[reportId], [reportId]/print, export-history),
properties/[id]/ (comparables, generate-report, risk-analysis, valuation)
├── components/ admin/ agent/ audit/ auth/ command/ common/ comparables/
consent/ dashboard/ export/ forms/ history/ landing/ language/
layout/ motion/ notifications/ profile/ property/ (+aggregation/, pdf/)
reports/ (+sections/) risk/ settings/ ui/ + ErrorBoundary,
I18nProvider, ThemeToggle, CommandPalette, PageTracker, BackButton...
├── constants/ apiRoutes.js, appConstants.js, labels.js, faq.js
├── hooks/ useAgentChat, useRiskAssessment, useAuth, useTheme, useAdminDashboard,
useUserManagement, useNotifications, useUnreadCount, useSse, useLocale,
useCommandPalette, useComparables, useCompareSelection,
usePropertyFilters, useReport, useReportHistory, useSavedComparisons,
useAuditLogs, useValuation, useNotificationPreferences,
usePageTracking, useAddressAutocomplete, usePropertyLabels
├── i18n/ index.js, formatters.js
├── lib/ docsData.js, celebrate.js
├── locales/ en, hi, bn, ta, te, mr, gu, kn, ml, pa, ur → translation.json
├── services/ api, authService, adminService, propertyService, reportService,
riskAssessmentService, subscriptionService, auditService,
notificationService, exportService, sseService, aggregationService,
comparableService, valuationService, dashboardService,
savedComparisonService, propertyLabelService, cloudinaryService
├── test/ setup.js (global mocks)
├── utils/ helpers, downloadUtils, currency, riskUtils, riskColor, formatDate,
validators, animations, analyticsUtils, enumTranslations,
exportConstants, geoUtils, labelUtils, mockAreaAverage,
notificationUtils, reportUtils
├── __tests__/ (8 test files – see §9.2)

```

```

|
├─ .github/workflows/ci.yml
├─ Dockerfile.backend · Dockerfile.frontend · docker-compose.yml · .dockerignore
├─ render.yaml · vercel.json (in frontend/)
├─ docs/ (ARCHITECTURE, DEPLOYMENT, api, DOCKER, SECURITY, E2E_DEMO_SCRIPT,
│   SUBMISSION_CHECKLIST, PROJECT_DOCUMENTATION)
├─ README.md · LICENSE

```

12. Design System

Token group	Values
Marketing dark theme	Git Hub-dark palette: bg <code>#0d1117</code> , card <code>#161b22</code> , elevated <code>#1c2128</code> , border <code>#30363d</code> , text <code>#e6edf3</code> / secondary <code>#7d8590</code>
Dashboard light	bg <code>#F6F8FB</code> , fg <code>#171717</code> , border <code>#e2e8f0</code> , primary <code>#16a34a</code>
Dashboard dark	bg <code>#0d1117</code> , fg <code>#e6edf3</code> , primary <code>#22C55E</code> , destructive <code>#f85149</code> , ring <code>#22C55E</code>
Radius	0.5 rem (cards/modals rounded-xl/2xl)
Typography	Geist Sans (body, <code>--font-geist-sans</code>) + Geist Mono (<code>--font-geist-mono</code>) via <code>next/font/google</code> ; Noto Sans per-script (10 Indic scripts) for i18n
Component library	shadcn/ui (components.json: style base-nova, baseColor neutral, lucide icons) on <code>@base-ui/react</code> primitives — button, badge, card, input, select, checkbox, dialog, dropdown-menu, sheet, table, separator, label, avatar + custom Skeleton, EmptyState, PageHeader, Breadcrumbs, ConfirmDialog, SearchableSelect
Tailwind v4	CSS-first config in <code>globals.css</code> : <code>@import "tailwindcss"</code> , <code>@custom-variant dark</code> , <code>@theme inline</code> maps CSS vars → <code>--color-*</code> tokens
Breakpoints	Tailwind defaults: <code>sm 640</code> , <code>md 768</code> , <code>lg 1024</code> (sidebar auto-collapse), <code>xl 1280</code>
Animation	framer-motion variants in <code>utils/animations.js</code> (<code>fadeInUp</code> , <code>fadeIn</code> , <code>scaleUp</code> , <code>staggerContainer</code> , <code>staggerItem</code>); springs in RiskSpectrum; AnimatePresence modals; NextTopLoader progress bar (<code>#22C55E</code>)

13. Third-Party Integrations

Integration	Where	Details
Groq (AI)	<code>AgentChatServiceImpl</code> + <code>ReportSummaryServiceImpl</code>	<code>https://api.groq.com/openai/v1/chat/completions</code> , model <code>llama-3.3-70b-versatile</code> ; chat: stream:true/max_tokens 1024/temp 0.7/120 s timeouts/retry backoff; summary: json_object/max_tokens 800/temp 0.4/45 s, verdict PROCEED-CAUTION-HIGH_RISK
Cashfree (payments)	<code>CashfreeServiceImpl</code> + <code>SubscriptionController</code>	Payment Links API, sandbox <code>https://sandbox.cashfree.com/pg</code> (prod <code>https://api.cashfree.com/pg</code>), <code>x-api-version: 2023-08-01</code> , HmacSHA256 webhook verify
Google OAuth	<code>GoogleTokenVerifier</code> , <code>GoogleOAuthHealthCheck</code> , frontend GIS	ID-token verify via <code>https://www.googleapis.com/oauth2/v3/certs</code> ; health check probes certs endpoint
Gmail SMTP	<code>EmailService</code> (all sends <code>@Async</code> , UTF-8 MIME)	<code>smtp.gmail.com:587</code> , STARTTLS required, 5 s timeouts; 9 email types (OTP, welcome, login alert, deletion, report ready, risk alert, contact, registration OTP)
WAQI	<code>WAQIHealthCheck</code> + <code>CpcbEnvironmentalProvider</code>	<code>https://api.waqi.info/feed/{city}?token=</code> , token <code>\${WAQI_TOKEN:demo}</code> , <code>@Retryable(3, backoff 500 ms x2)</code> , station sanity check, AQI categories GOOD → SEVERE, mock fallback
Nominatim (OSM)	<code>GeocodingServiceImpl</code> + <code>NominatimHealthCheck</code> + <code>useAddressAutocomplete</code>	<code>https://nominatim.openstreetmap.org/search?countrycodes=in</code> , UA <code>DueDiligenceAgent/1.0</code> , 1 req/s spacing, 5 s/8 s timeouts
Cloudinary	frontend only: <code>cloudinaryService.js</code> → <code>ImageUploader.jsx</code> , <code>AvatarUploader.jsx</code>	Unsigned-preset browser-direct upload (5 MB, JPEG/PNG/WebP), URL stored on <code>properties.image_url</code> / user avatar

Integration	Where	Details
GA4	<code>components/consent/*</code> + <code>usePageTracking</code>	Consent-gated (v2 cookie-consent categories), anonymize_ip, cookie cleanup on reject
OpenStreetMap tiles / Leaflet	<code>ComparableMap.jsx</code> , <code>PortfolioMap.jsx</code>	OSM + CARTO dark tiles

14. Known Issues & Fixes Applied

Issue	Fix	Commit
JWT_SECRET silently missing → WeakKeyException 500s (friend's "jwt fix" era)	<code>JWT_SECRET</code> fail-fast validation; secret confirmed 75 chars in <code>backend/.env</code> ; login works	(session fix, Aug 15–16)
Google-only accounts (NULL password) got generic "invalid credentials" on password login	<code>login()</code> pre-check: 400 "This account uses Google Sign-In. Please continue with Google."	<code>8fedc53</code>
NULL <code>is_active</code> broke ALL logins (M4 <code>.disabled(!active banned)</code>)	<code>CustomUserDetailsService</code> : NULL treated as active (<code>!Boolean.FALSE.equals</code>); DB backfilled	<code>8fedc53</code>
Stray merge-conflict marker <code><<<<<< HEAD</code> in <code>application.properties</code> (M4 push)	removed	<code>84daef0</code>
Admin list "Active" vs detail "Inactive" for same user (NULL <code>is_active</code>)	null-safe <code>isActive !== false</code> in table/filter/counts/detail + <code>@Column(nullable=false)</code> + V11 SQL backfill/DEFAULT/NOT NULL	<code>d6ec97d</code>
Google Sign-In "500 Internal Server Error" after recompile	Transient backend-restart window; api.js now retries non-JSON 5xx once (2 s) with "Server is restarting" message; blips log as warn	<code>9759f08</code>
Corrupted UTF-8 ellipsis	replaced with ASCII	<code>3beca2b</code>
Cashfree: wrong payment flow	switched to Payment Links API (<code>/links</code>), widened poll window, repurchase extension, unlimited sentinel, admin exemption	<code>302060d</code> , <code>7ffb07b</code> , <code>54f4199</code>
PDF downloads broken in various ways (blob URLs, hidden iframe, auth)	cookie-based direct URL downloads, JSON-error detection, iText font reload per request, admin bypass	<code>3ab7c06</code> ... <code>balleca</code> cluster
CSP blocked blob: URLs	<code>blob:</code> added to CSP	<code>e818a01</code>
Locale translation corruption / dark-mode regressions / hydration	repaired en/hi (and other) translation JSONs; dark-mode color-scheme; hydration fix	<code>d913dbc</code> , <code>85db73b</code> , <code>d6c736c</code> , <code>b1d7409</code>
Secrets committed	moved all to <code>.env</code> + <code>.env.example</code> templates	<code>ad56080</code>

Known remaining quirks (documented, not blockers): `NEXT_PUBLIC_GA` vs `NEXT_PUBLIC_GA4_MEASUREMENT_ID` naming mismatch in `.env.example`; `GOOGLE_CLIENT_ID` / `WAQI_TOKEN` / `CASHFREE_ENV` not passed in docker-compose backend env; V10/V11 SQL files exist but no Flyway dependency (ddl-auto manages schema); `vercel.json` rewrite host is a placeholder; Cashfree return/notify URLs hardcoded to localhost; 5 zero-byte stub files (`LoginForm.jsx` , `useFetch.js` , `Footer.jsx` , `PropertyCard.jsx` (dashboard), `ChartCard.jsx`); orphaned `components/command/CommandPalette.jsx` imports uninstalled `cmdk` (active palette is `components/CommandPalette.jsx`).

15. Future Scope

Item	Rationale
Document upload & OCR verification	Parse sale deeds/encumbrance certificates automatically (Tesseract/Google Vision) instead of manual data entry
Multi-language support (Hindi, Kannada)	Translation files exist; extend to full content coverage + locale-specific dates/currencies (formatters already Intl-based)
Mobile app (React Native)	Reuse the same API; JWT + SSE stack is mobile-ready
Real-time notifications (WebSocket)	Upgrade from SSE long-poll for bidirectional push (chat typing, live risk updates)

Item	Rationale
Advanced analytics dashboard	ML-based price prediction, fraud-pattern clustering, city-level heatmaps (backend already records activity + heatmaps)
Government land-records API integration	Real encumbrance + ownership data (currently mock/aggregated providers) — biggest accuracy unlock
Blockchain-based property verification	Tamper-proof title-chain registry
Flyway migration tooling	Wire Flyway so V10/V11-style SQL actually runs in deployments
Production-hardened URLs	Configurable Cashfree return/notify URLs, Vercel rewrite host, CORS domains

16. Recent Changes / Changelog

Recent Improvements (Week 4)

- **Full RBAC audit + fix** across 21 files (backend + frontend): shared `RoleUtils` helper, service-layer owner-or-view-all checks on every property-data read path, `@PreAuthorize` on audit/health/test controllers, comparables/saved-comparisons opened to all roles, UI visibility per role (billing/checkout/upgrade hidden for pro roles).
- **Netflix/Stripe-style subscription cancel**: `status=CANCELLED` keeps paid access + unlimited reports until `expires_at`, then auto-downgrades to FREE; re-purchase extends +1 month from current expiry.
- **Removed all fake feature claims** from pricing, checkout, and billing pages (no white-label/priority/team-seats/API/SLA claims) — replaced with only real, shipped features.
- **Property delete with ON DELETE CASCADE** (`V12__cascade_property_deletes.sql`): snapshots, labels, valuations, comparable analyses/properties, report history all cascade.
- **`is_active` null-safe** (`V11__fix_is_active.sql`): backfill + `NOT NULL DEFAULT true`; frontend uses `isActive !== false` everywhere.
- **LEGAL_REVIEWER + FINANCIAL_INSTITUTION treated as read-only professionals**: view all properties, unlimited reports, no plan limits, no billing UI, no add/edit/delete, no report deletion.
- **ADMIN sidebar restored Property Search link** (admin platform menu now includes it).
- **Dead code removed**: Property Labels UI (admin section, FEATURED badge, `PropertyLabel*.jsx`, `usePropertyLabels`, `propertyLabelService`, `labelUtils`, `constants/labels.js`, i18n `labels` keys) — backend label endpoints left intact for DB safety.
- **Backend endpoint role reviews**: comparables/valuation/risk/AI-summary now enforce ownership or view-all role (previously readable by any authenticated user via ID).
- **Checkout guard for professional roles**: LEGAL/FIN visiting `/checkout` get toast “Your account has unlimited access — no subscription needed.” and redirect to `/dashboard` before any API call.
- **Usage counter + upgrade UI** on the report generation page: unlimited pill, “X of 3 free reports used”, upgrade card at 0 remaining, 402 upgrade modal.
- **Frontend API resilience**: 5xx-without-JSON-body (backend restarting) auto-retries once and shows “Server is restarting” instead of a fake “Internal Server Error” (commit `9759f08`).

Generated from the actual codebase — every endpoint, table, route, test and version above was read from source.